

Buy vs Build Decision Governance

Chapter 02 · Episode 1 — Dr. Michael Solomon

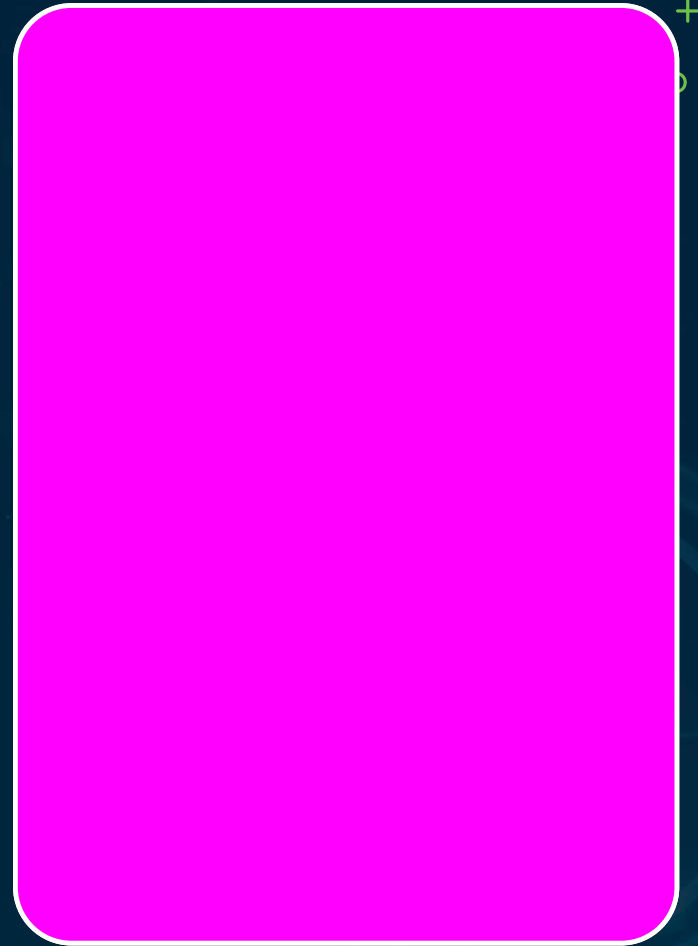


Governance Owns This Decision

Build vs buy sets your EU AI Act role

Provider (build) vs deployer (buy)

Not procurement's call alone



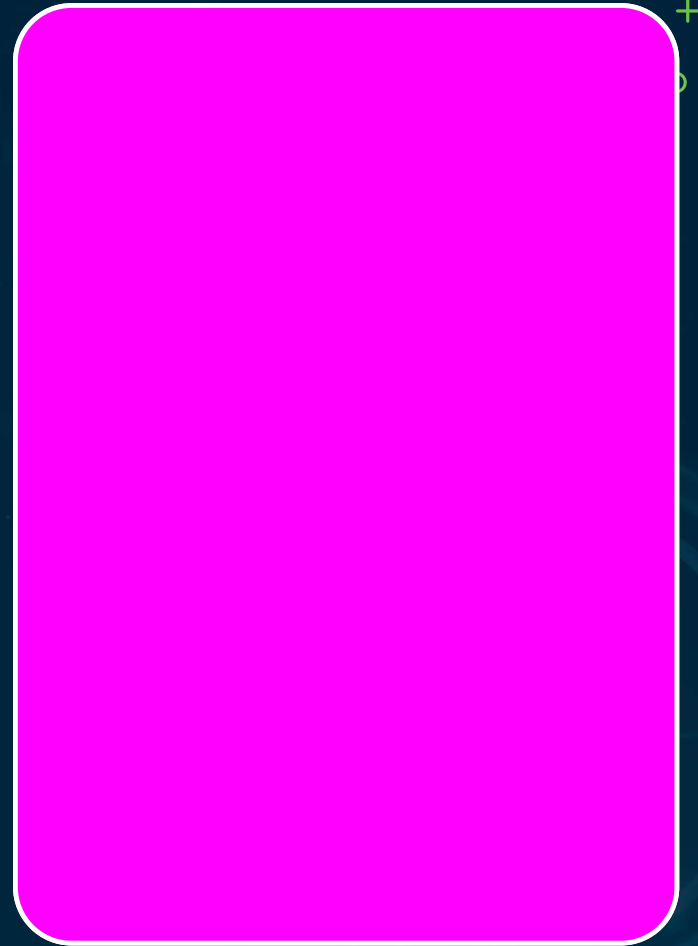
Build → Provider

Full EU AI Act provider obligations

Conformity · tech docs · CE · QMS

Post-market surveillance

IP clear; obligations resource-heavy



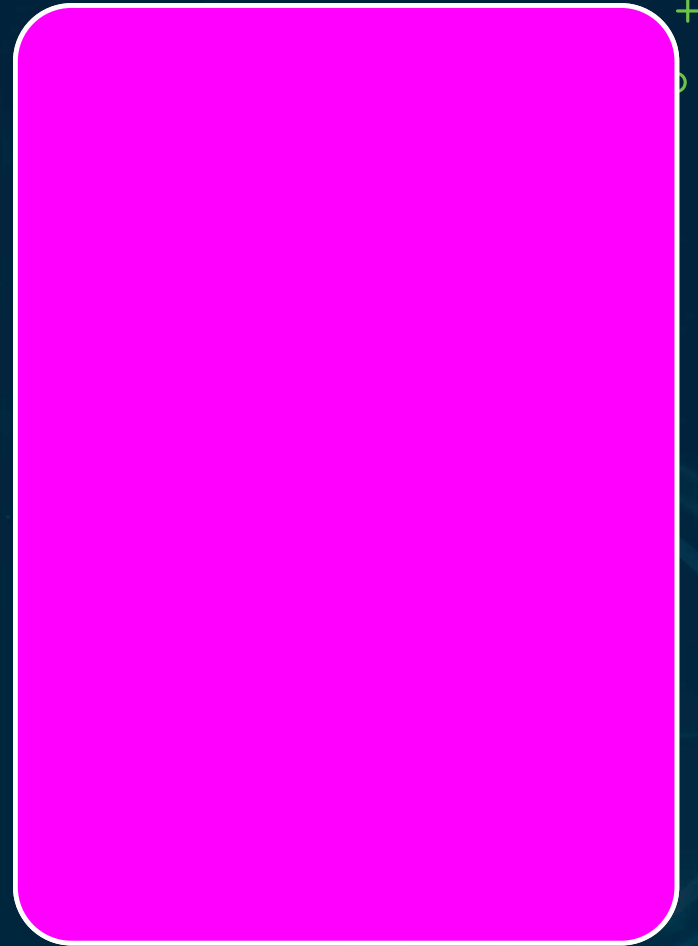
Buy → Deployer

Deployer obligations + vendor DD

FRIA · human oversight · logging

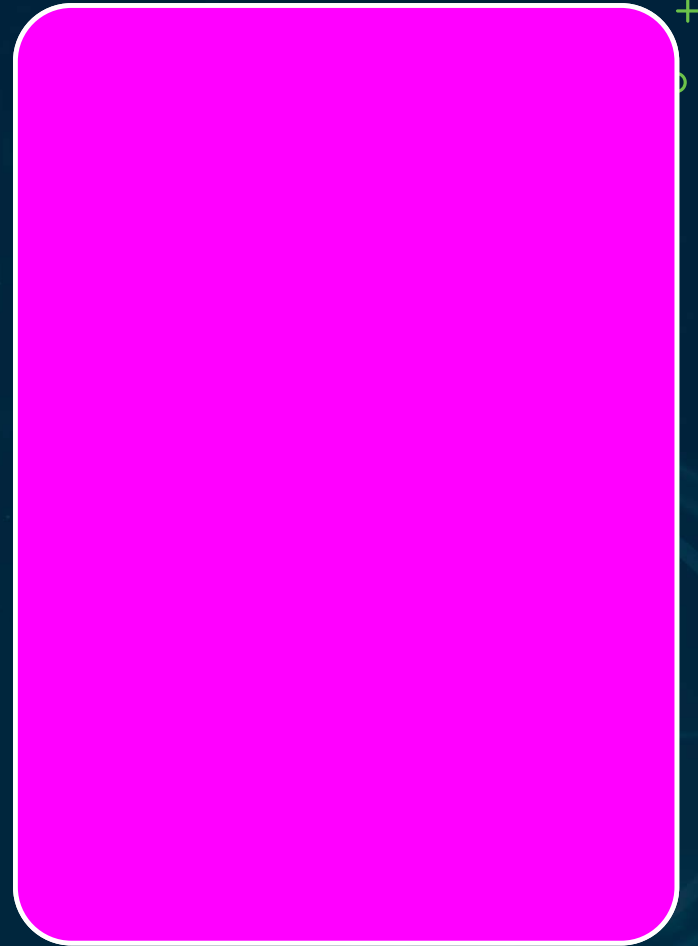
Transparency · incident notification

Verify vendor docs — duties nontransferable



Fine-Tune → Deemed Provider

Substantial modification flips the role
Legal review is mandatory
If yes: full provider + conformity first



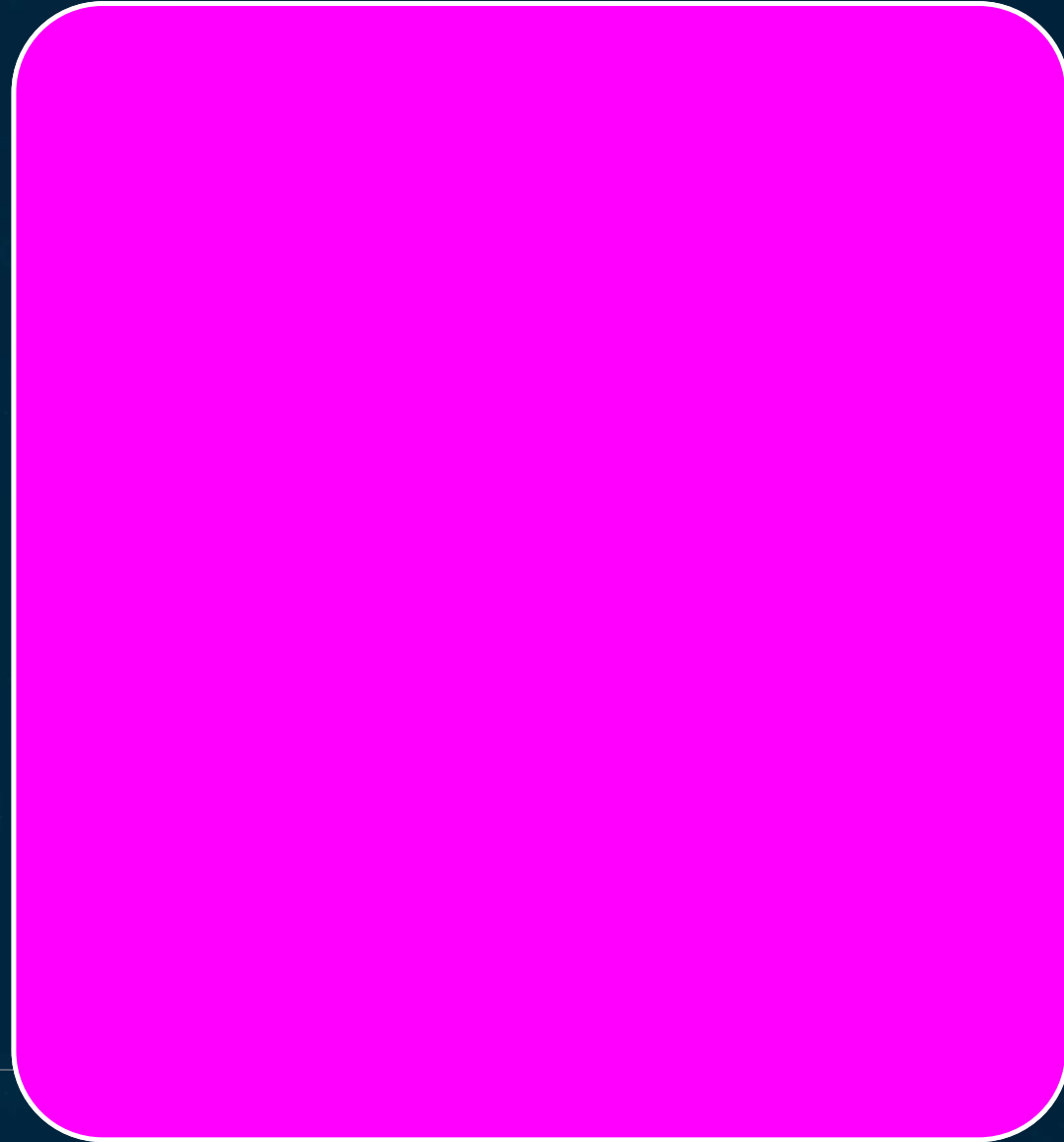
API Access → Deployer

Model weights stay vendor property

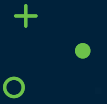
Output & commercial rights per ToS

Model-change + termination risk

No model = BCP required



Four Deployment Models → EU AI Act Role



BUILD

Provider — full obligations



FINE-TUNE

Deemed provider if substantial



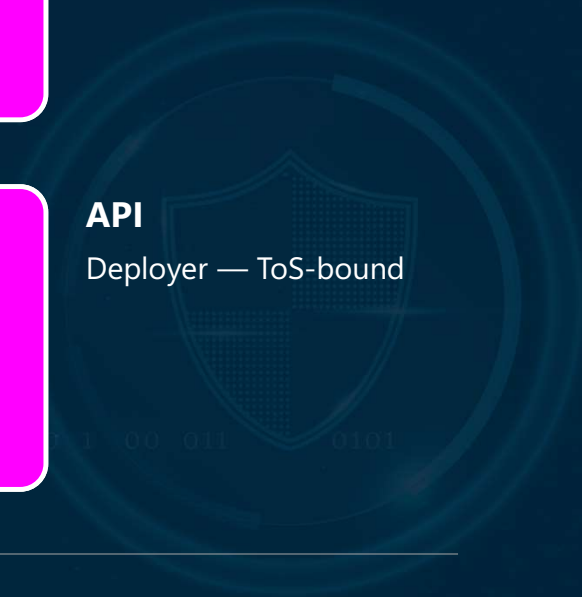
BUY

Deployer + vendor DD



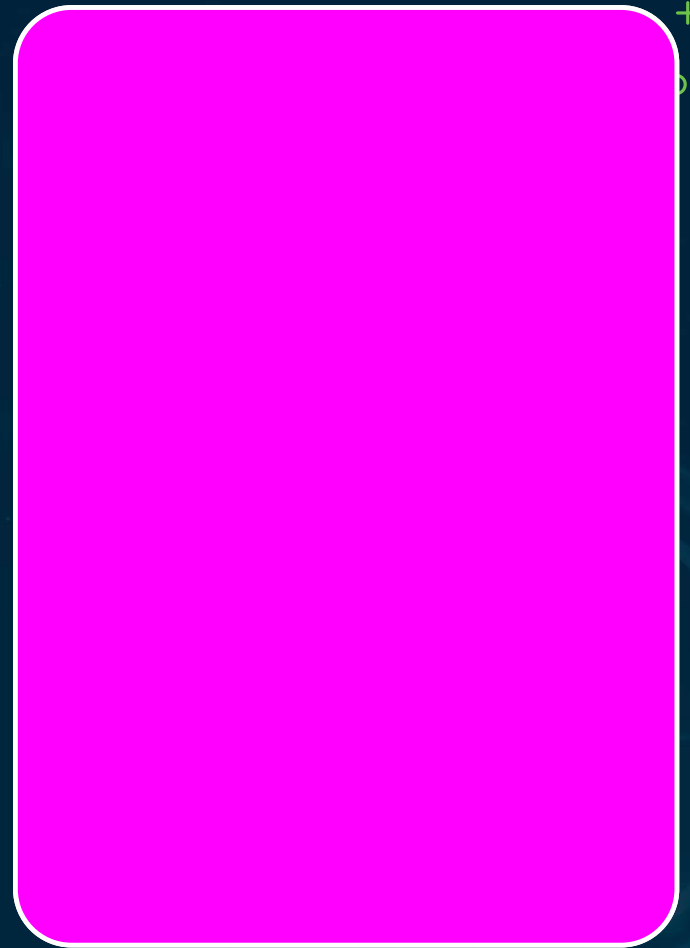
API

Deployer — ToS-bound



Data Governance Implications

Both: asset inventory · DPIA · register
Build: provenance · integrity · registry
Buy: change monitoring · vendor metrics
Buy: supply-chain risk assessment

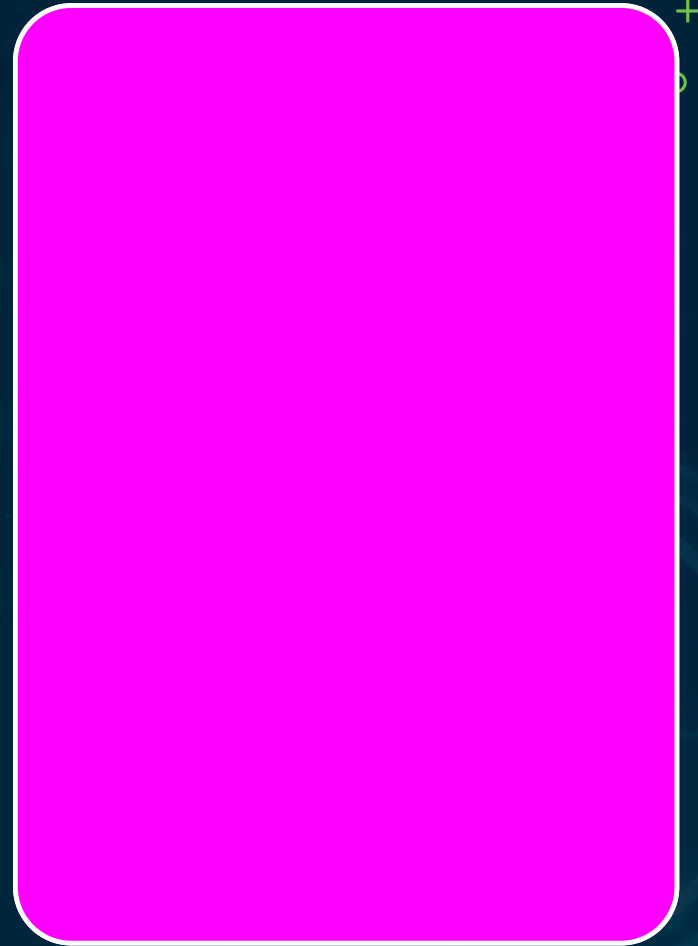


Recap

Four deployment models

EU AI Act role per model

Document the decision in the program plan



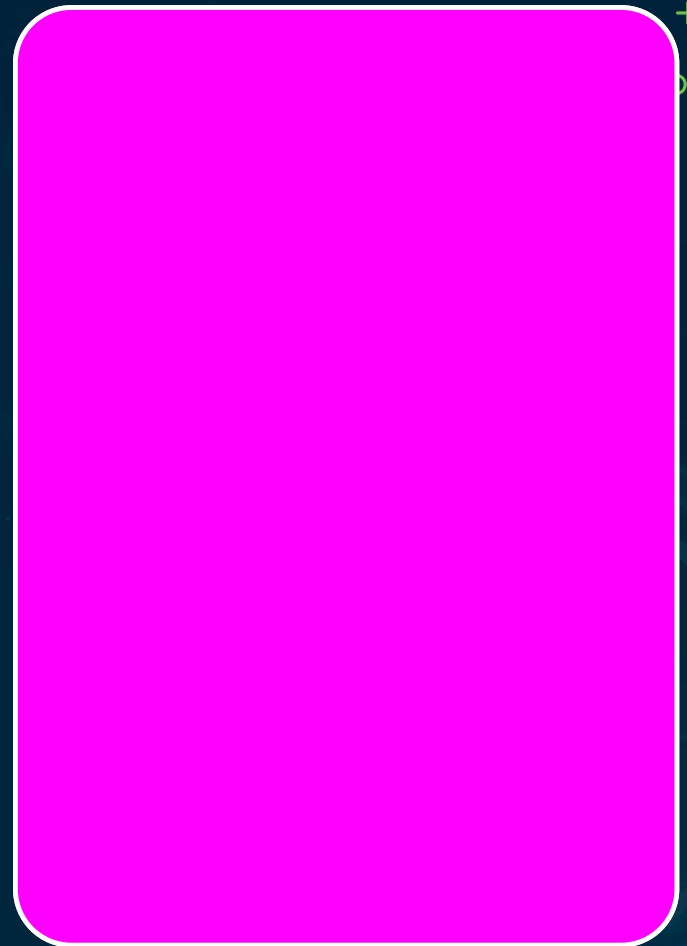
On the Exam

Build = provider

Buy = deployer

Fine-tune = deemed provider

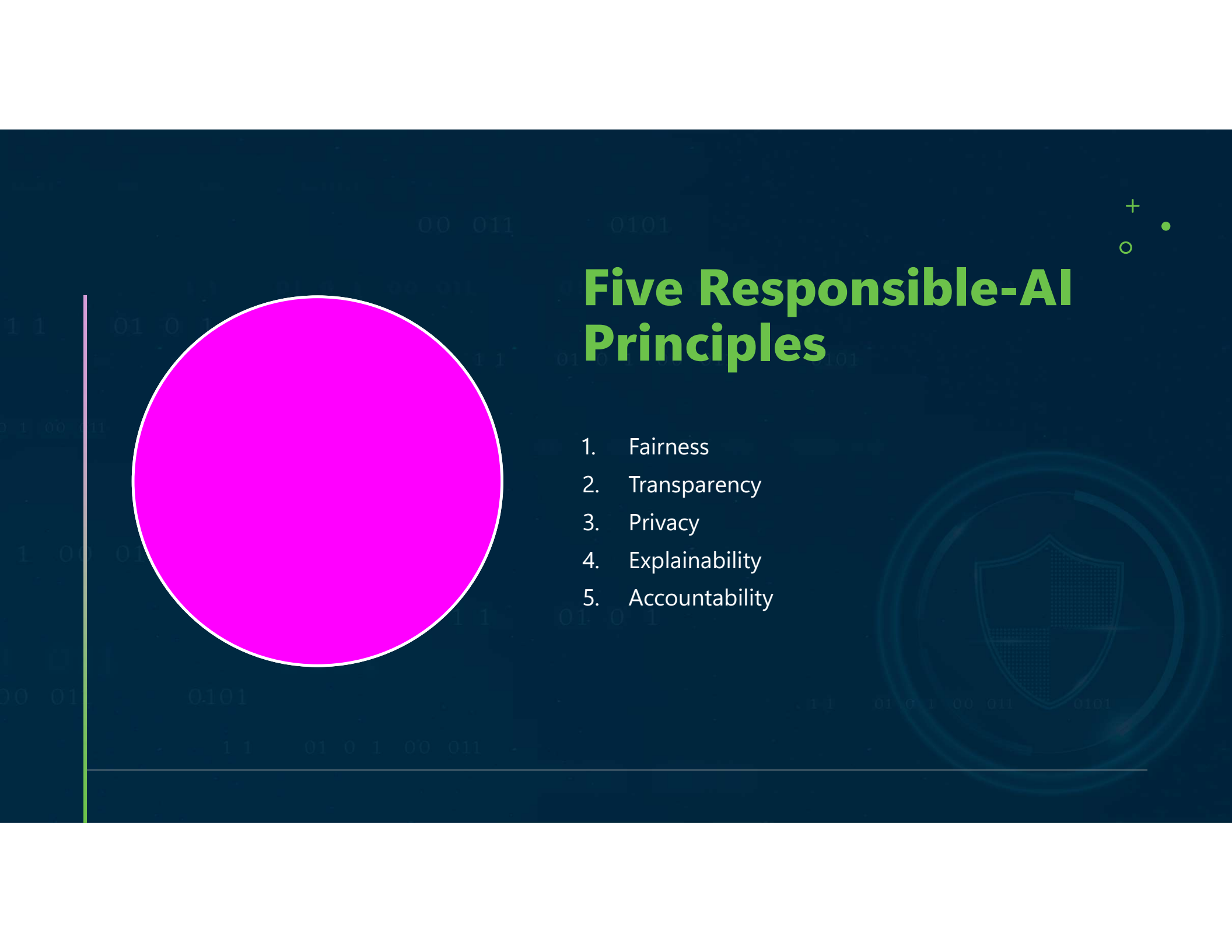
API = deployer



AI Policy Development & Responsible Use

Chapter 02 · Episode 2 — Dr. Michael Solomon





Five Responsible-AI Principles

1. Fairness
2. Transparency
3. Privacy
4. Explainability
5. Accountability

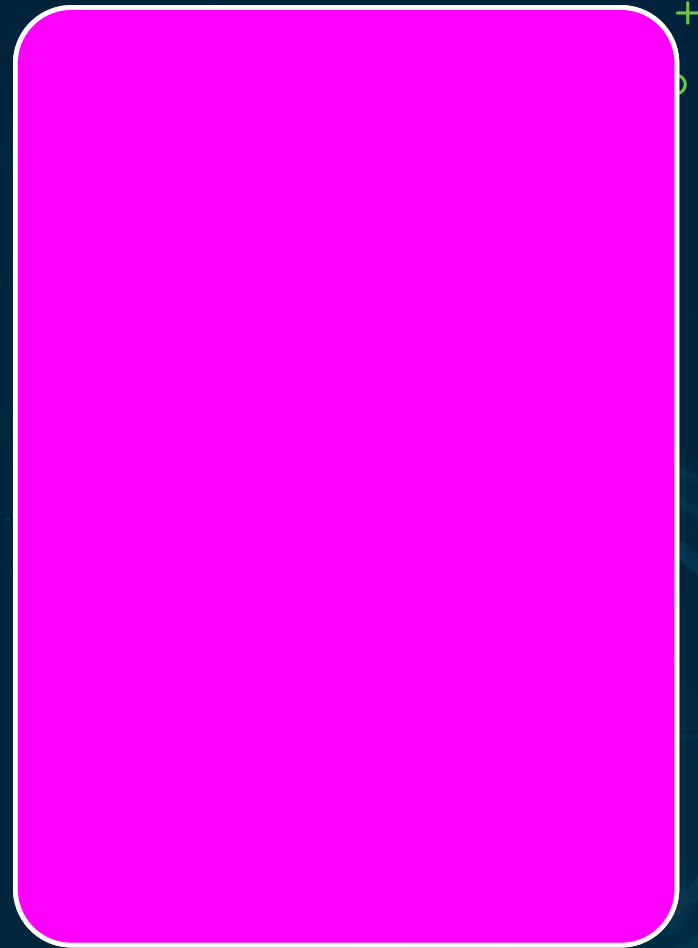
Fairness

Demographic parity — equal positive-outcome rates

Equal opportunity — equal error rates

Violated when rates differ without justification

e.g. fraud flagging skewed across groups



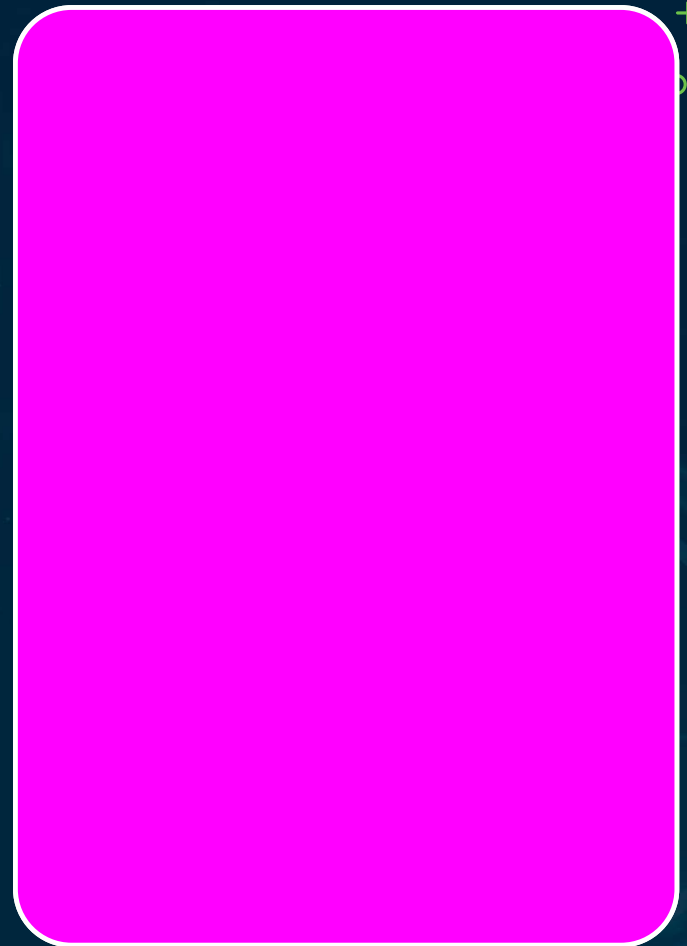
Transparency

Communicate existence, purpose, capabilities, limits

Not full disclosure of model internals

Regulated: credit, healthcare, employment

Violated when decision-making is hidden



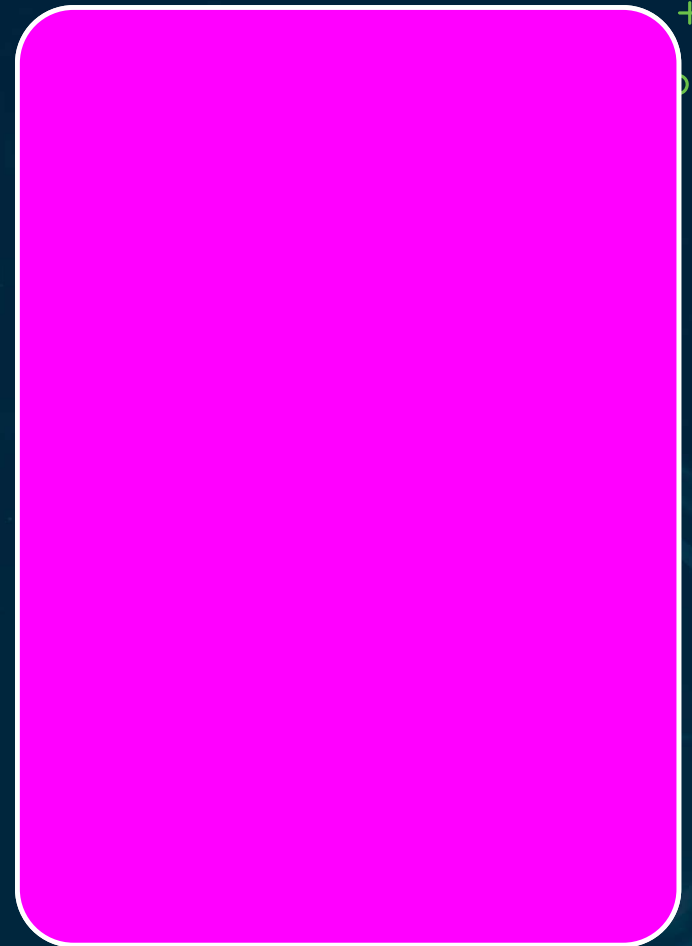
Privacy — Three AI-Specific Risks

Inference attacks — infer sensitive attributes

Training-data memorization — reproduce personal data

Re-identification of anonymized data

Privacy by design: minimization, purpose, consent



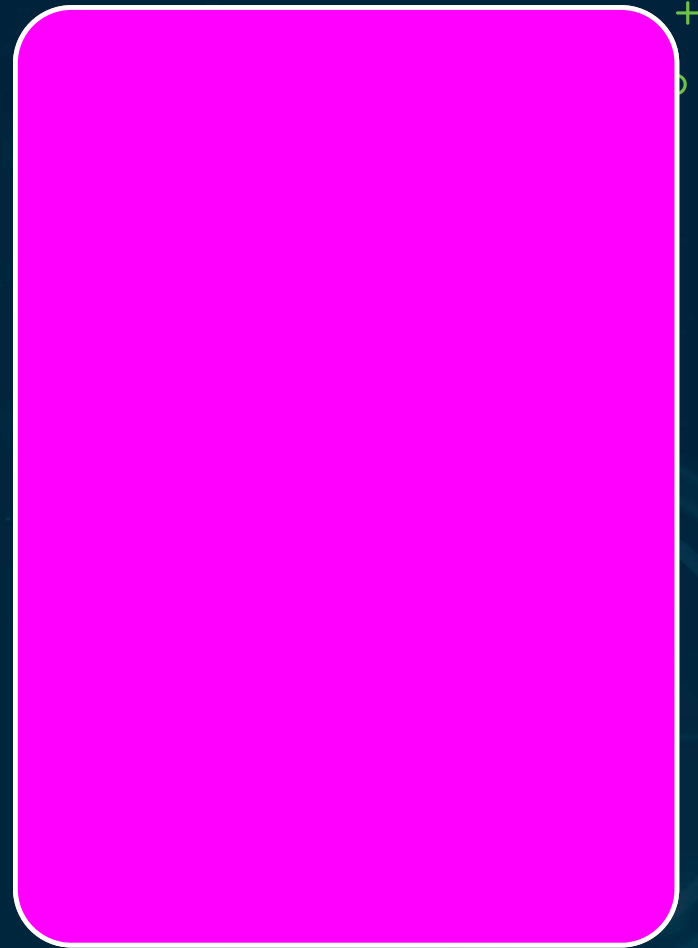
Explainability

Meaningful human account of a specific decision

Explainability $\neq$ interpretability

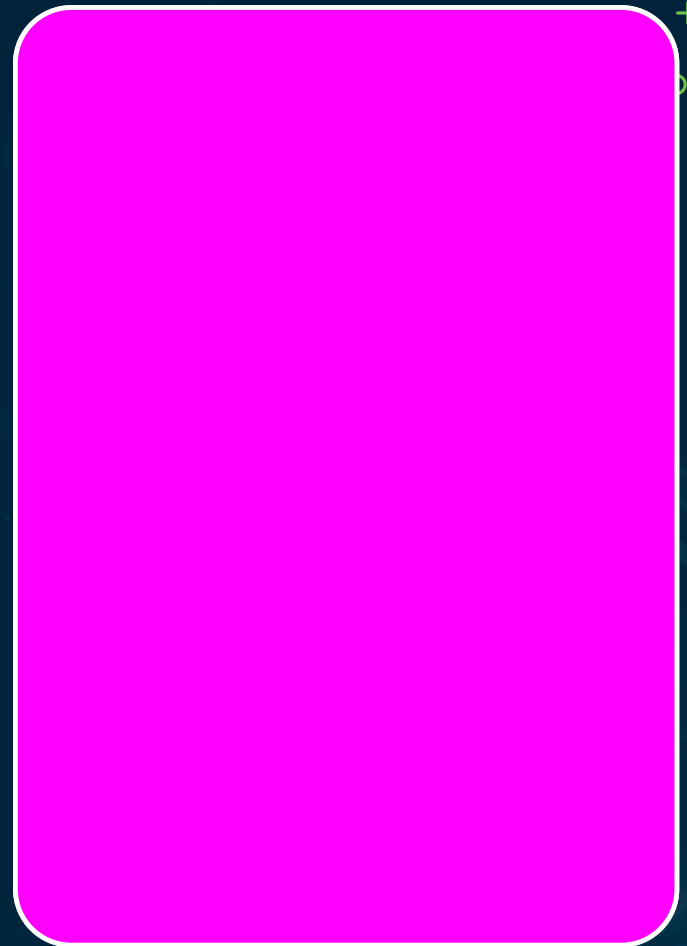
LIME — local approximation with a simpler model

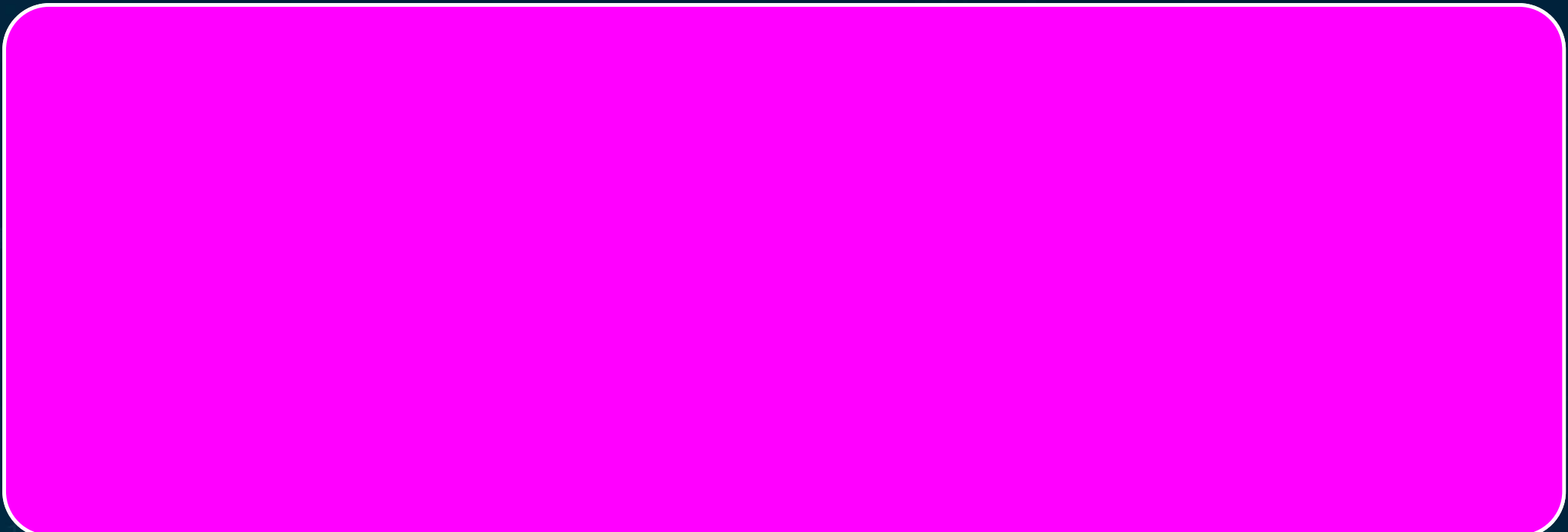
SHAP — feature-contribution scores via game theory



Accountability

Clear role ownership + audit trails
Attributes decisions to responsible parties
Completes the responsible-AI framework





Demo · Responsible-AI Scorecard

Evaluate an AI system against all five principles in Google Colab — fairness (parity + equal opportunity), the three privacy risks, LIME/SHAP — producing a compliance scorecard.

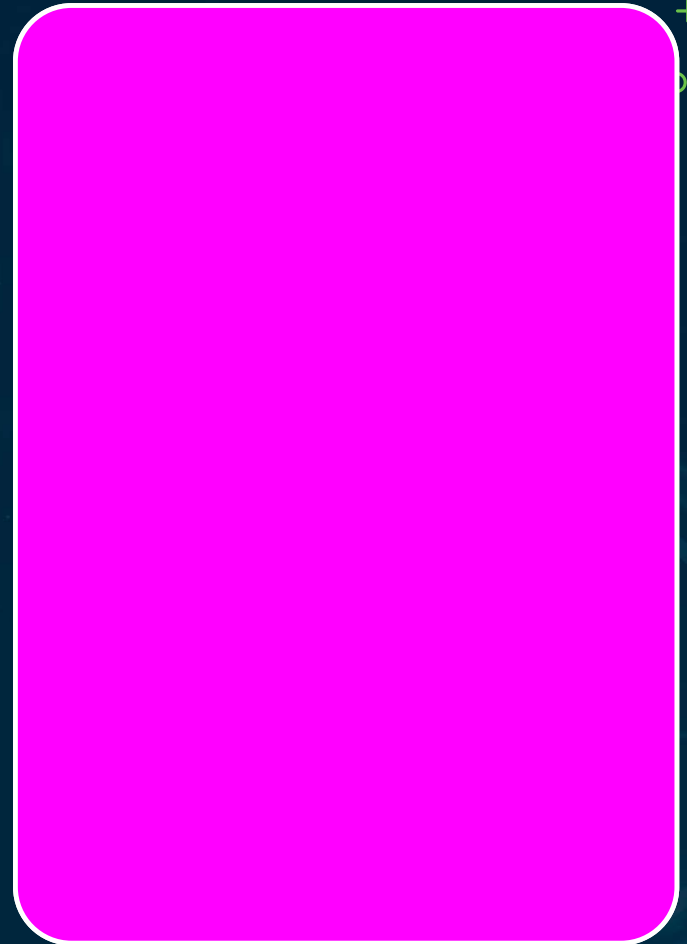
Exam Tips

Five principles — definition, implementation, violation

Fairness: demographic parity vs equal opportunity

Privacy: three risks beyond compliance

LIME (local approx) vs SHAP (feature contribution)



AUP – Three AI Risk Categories



Synthetic Media

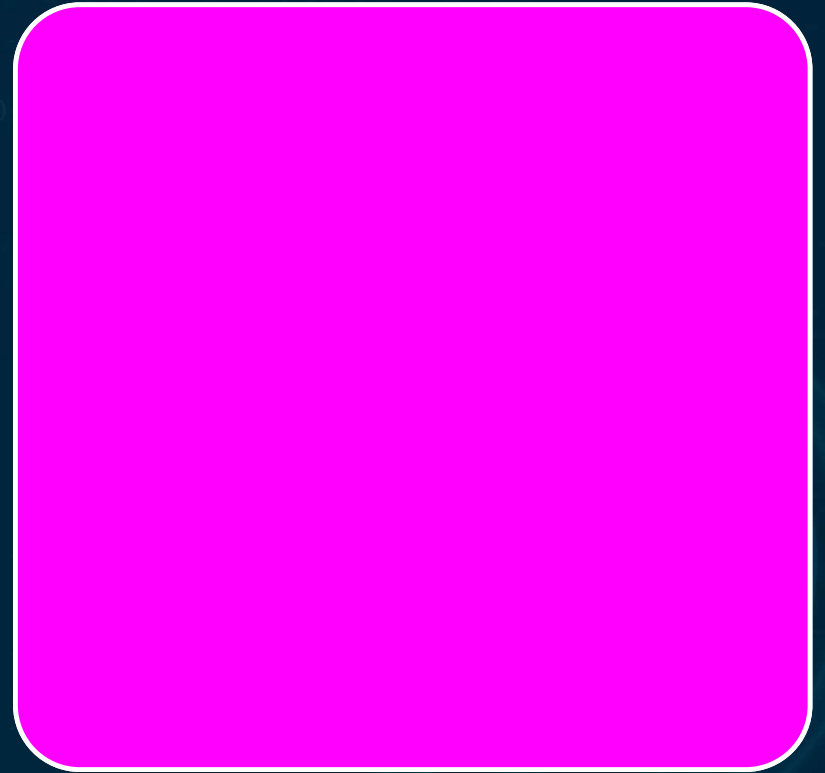
Prohibit deepfakes of
colleagues / customers

Automated Decisions

Define which need
human review

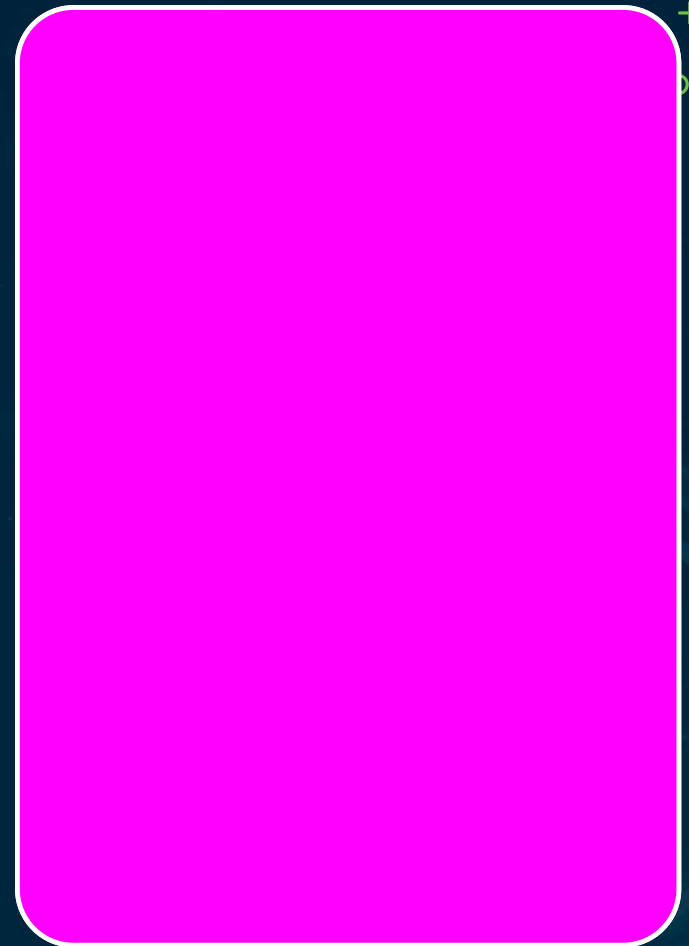
Third-Party Tools

Policy on personal /
consumer AI accounts



AUP Jurisdiction & Review

EU AI Act mandates AUP content for high-risk AI
Reference NIST AI RMF governance function
Sector guidance: OCC/FDIC, FDA, EEOC
Review at least annually + on material change

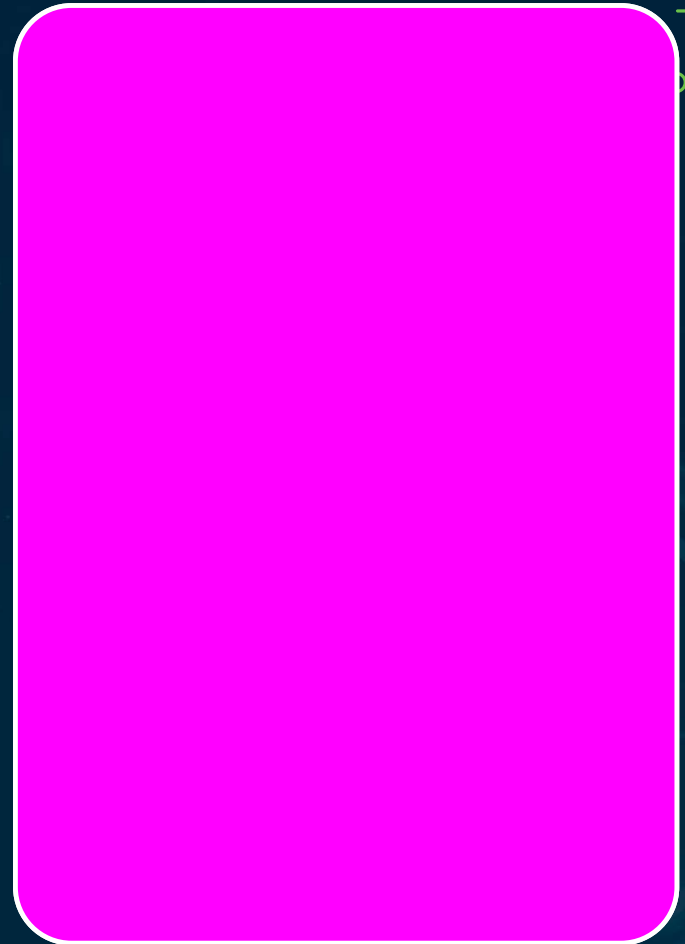


Corporate AI Policy — Three Dimensions

Sanctioned vs unsanctioned AI use

Private vs public AI models

Sensitive-data governance for AI

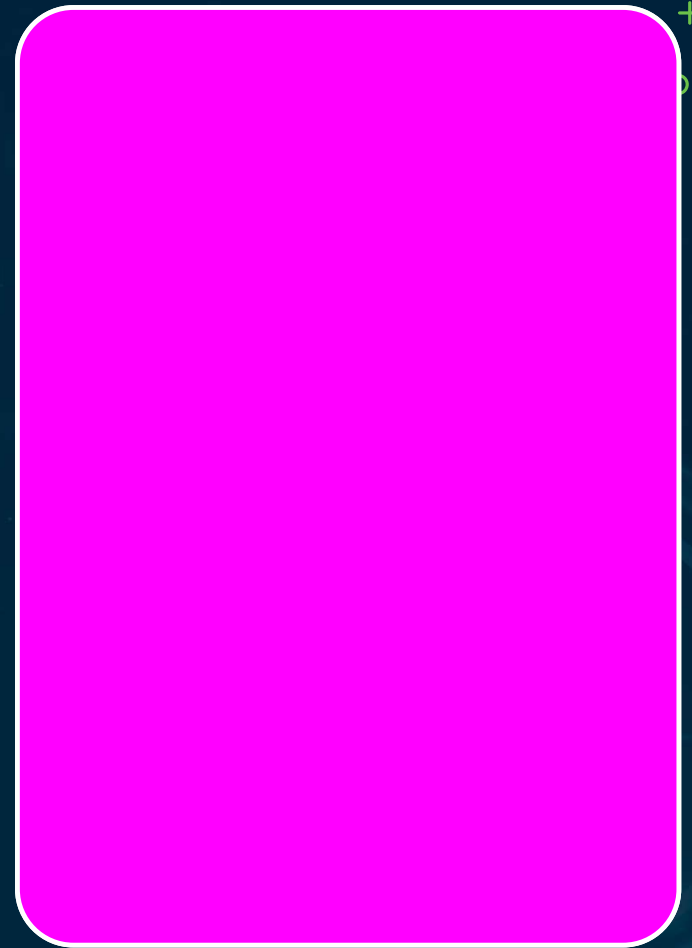


Sanctioned vs Unsanctioned AI

Sanctioned = assessed, configured, authorized

Unsanctioned = shadow AI, no authorization

Define approval process + sanctions + pathways

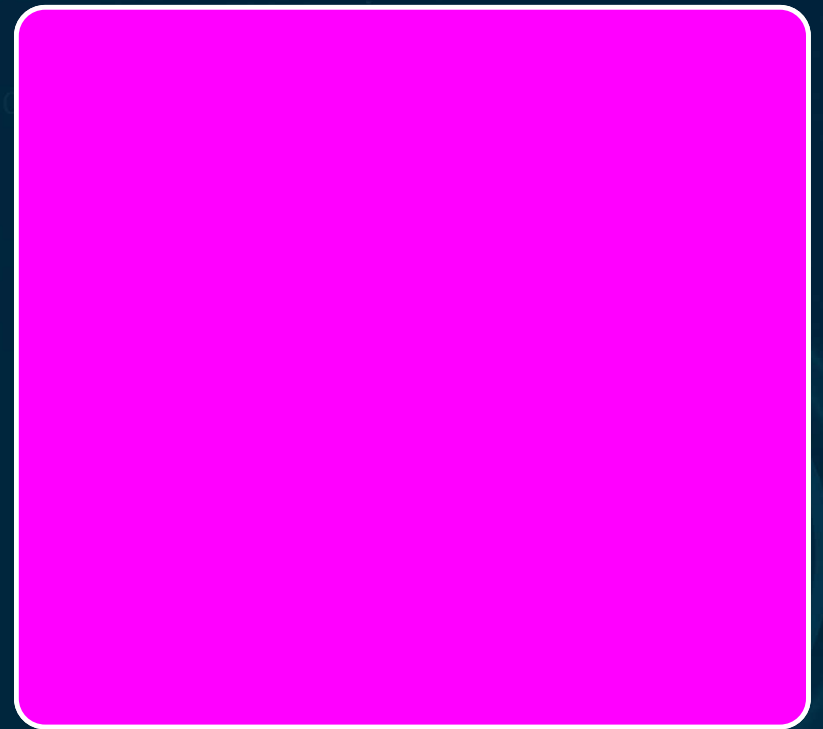


SANCTIONED USE REGISTER

Maintained list of approved tools + use cases + data types + owners

The compliance baseline for audit

Its absence = no verifiable baseline



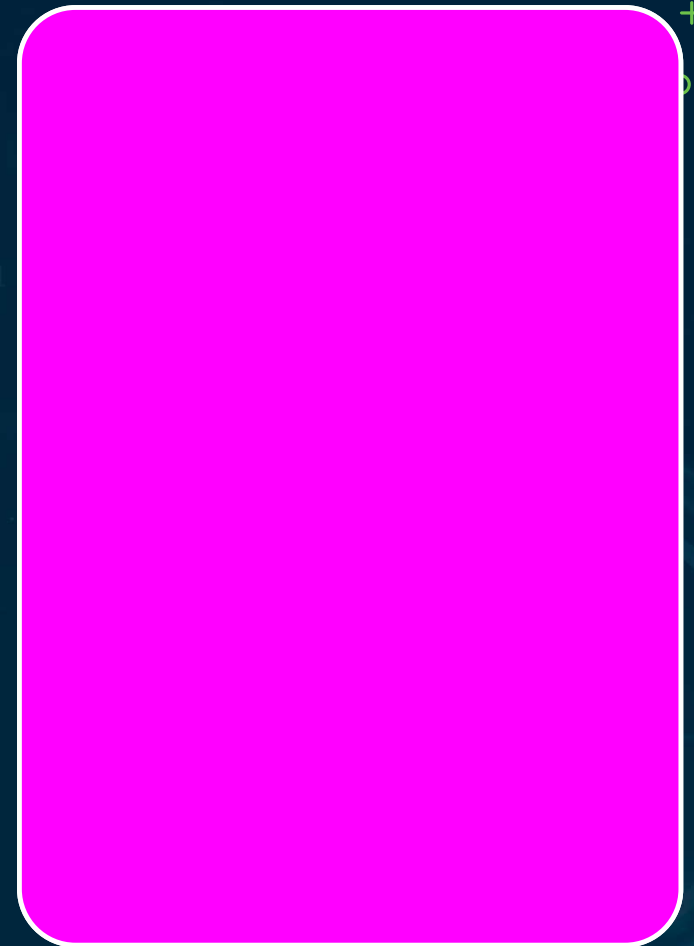
Sensitive-Data Governance for AI

Traditional classification wasn't built for AI inference

Training-data provenance + license

Inference-time handling + output filtering

Retention/deletion + cross-border flows



Model-Lifecycle Data Governance



Pre-Training

Classification,
minimization,
consent, license

Training

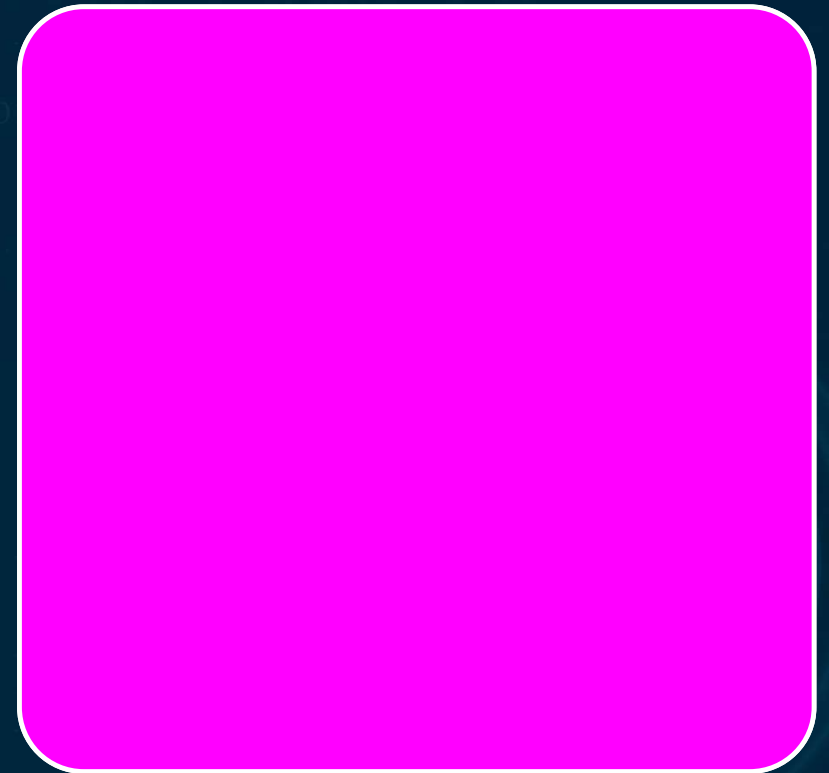
Environment isolation,
access controls, logging

Deployment

Inference handling,
output filtering,
flow monitoring

Retirement

Artifact deletion, non-
reconstruction, docs

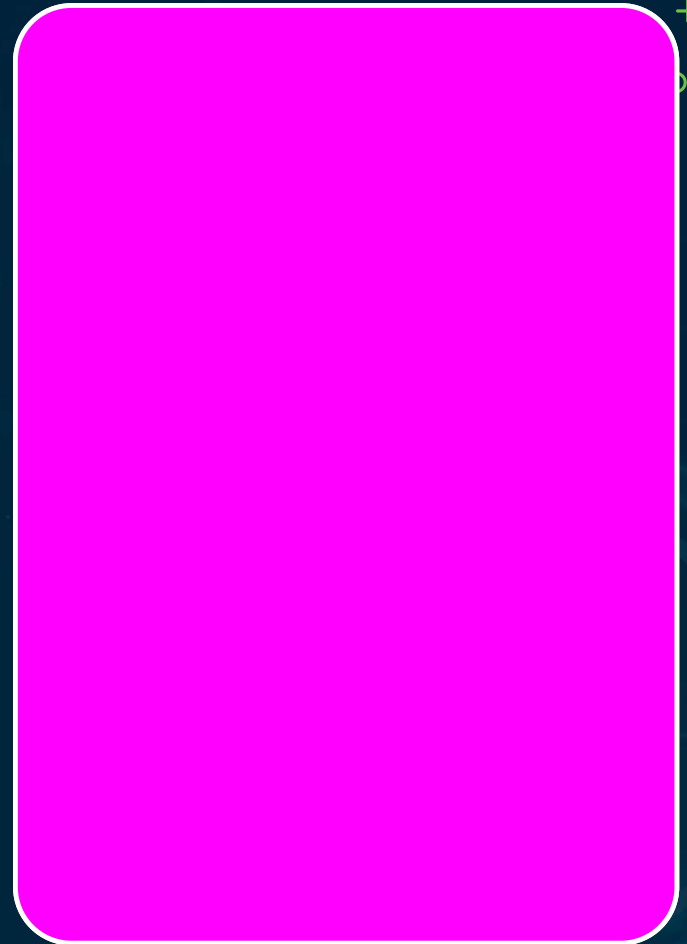


Recap · AI Policy & Responsible Use

AUP structure + required prohibitions

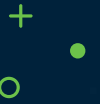
Three AUP categories: synthetic media, automated decisions, third-party tools

Review annually + on material AI strategy change



Governance Procedures & Manuals

Chapter 02 · Episode 3 — Dr. Michael Solomon



Four Procedure Types



IN
Intake



WATCH
Monitoring



DECIDE
Approval



RESPOND
Incident Response

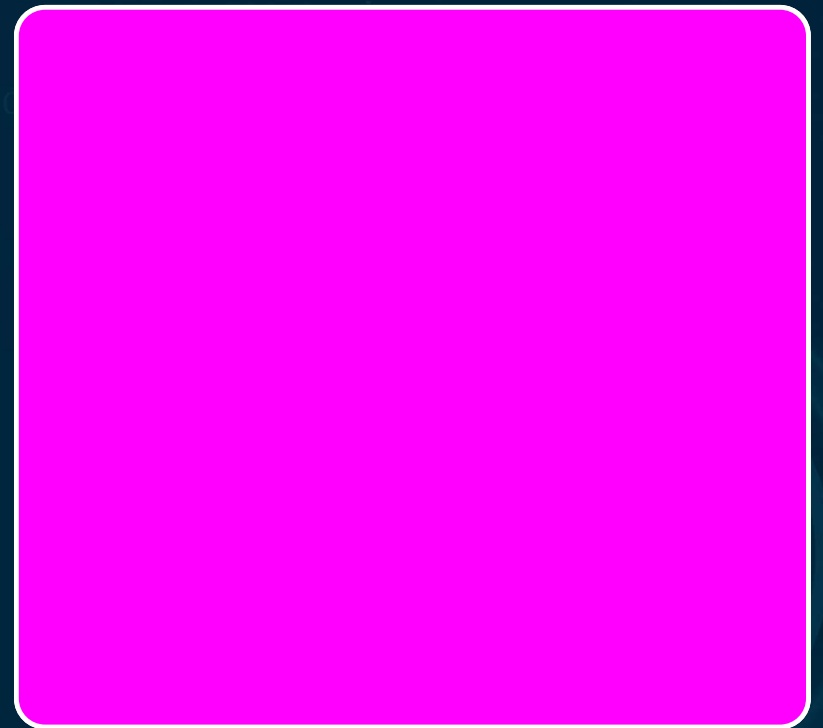


INTAKE

Use case → deployment approval

Requester, owner, purpose, data, risk

Triggers the risk-based track

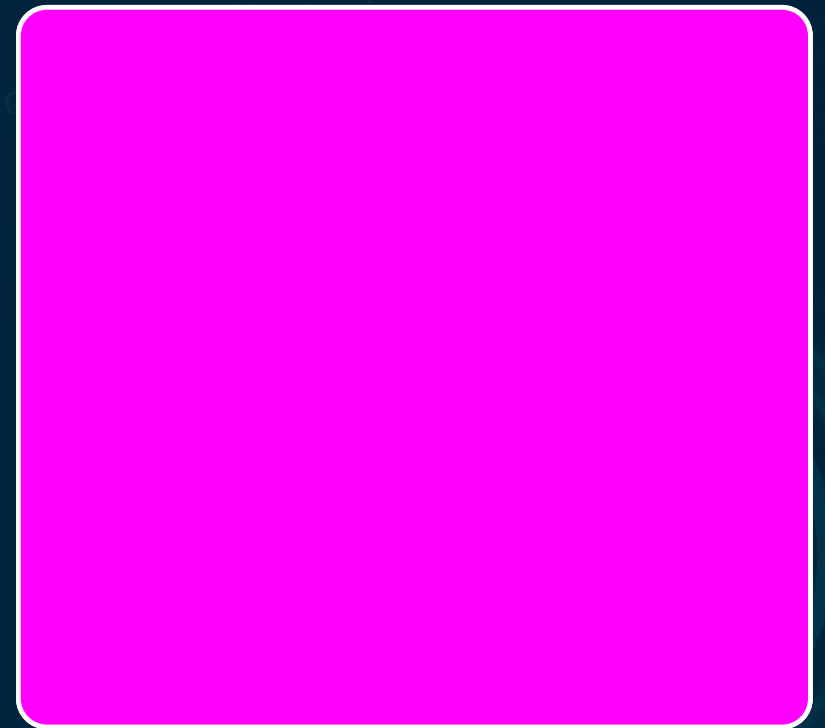


APPROVAL

Standard → program team

Enhanced → security lead

Full → steering committee

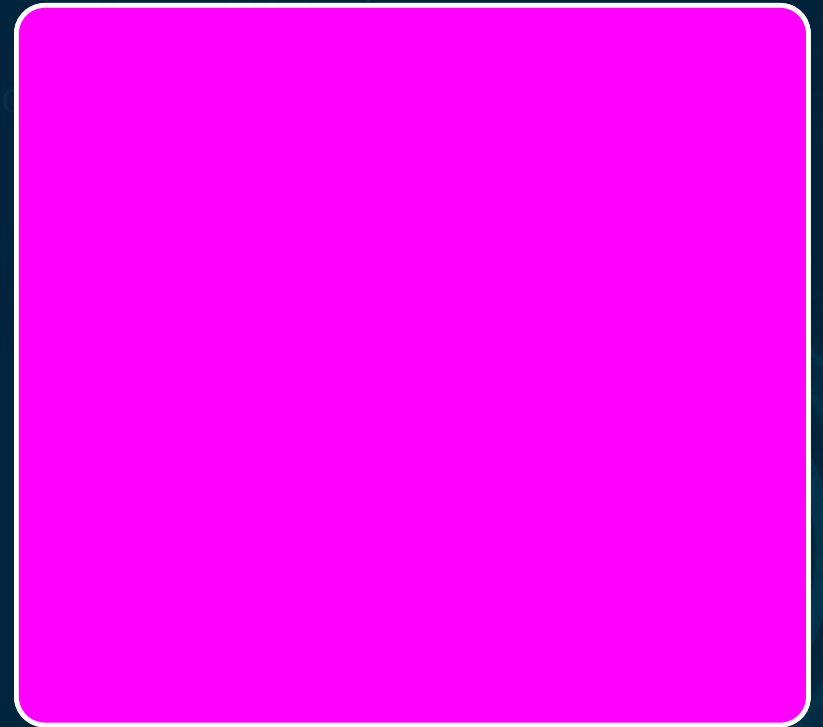


MONITORING

Cadence + escalation per system

Baselines set at deployment

CRI breach → documented escalation

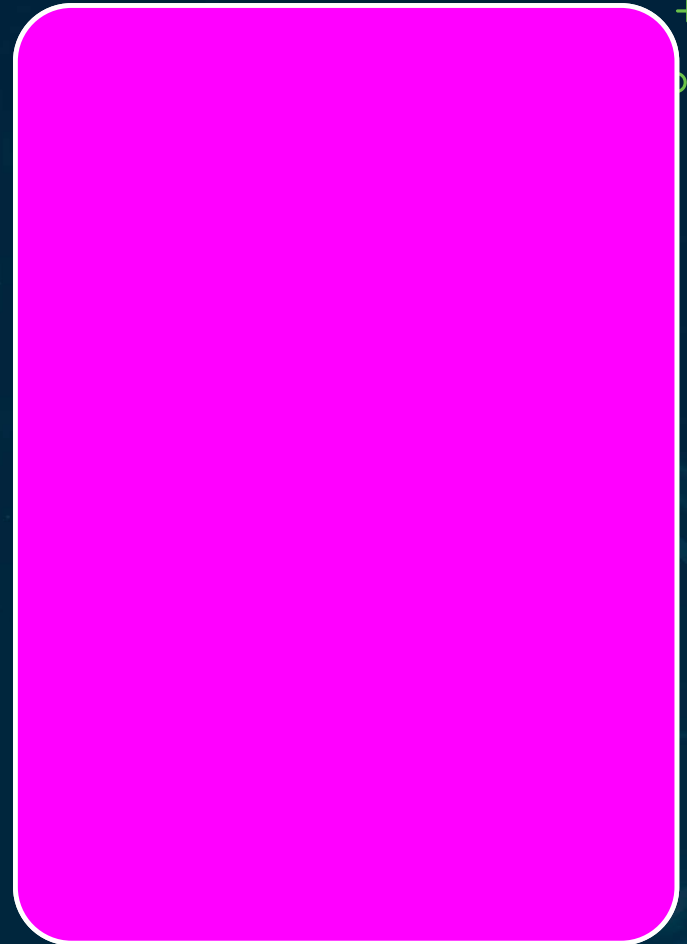


Procedure Governance

Review annually at minimum

Version: number, effective & review date

Gaps = control gaps → risk register

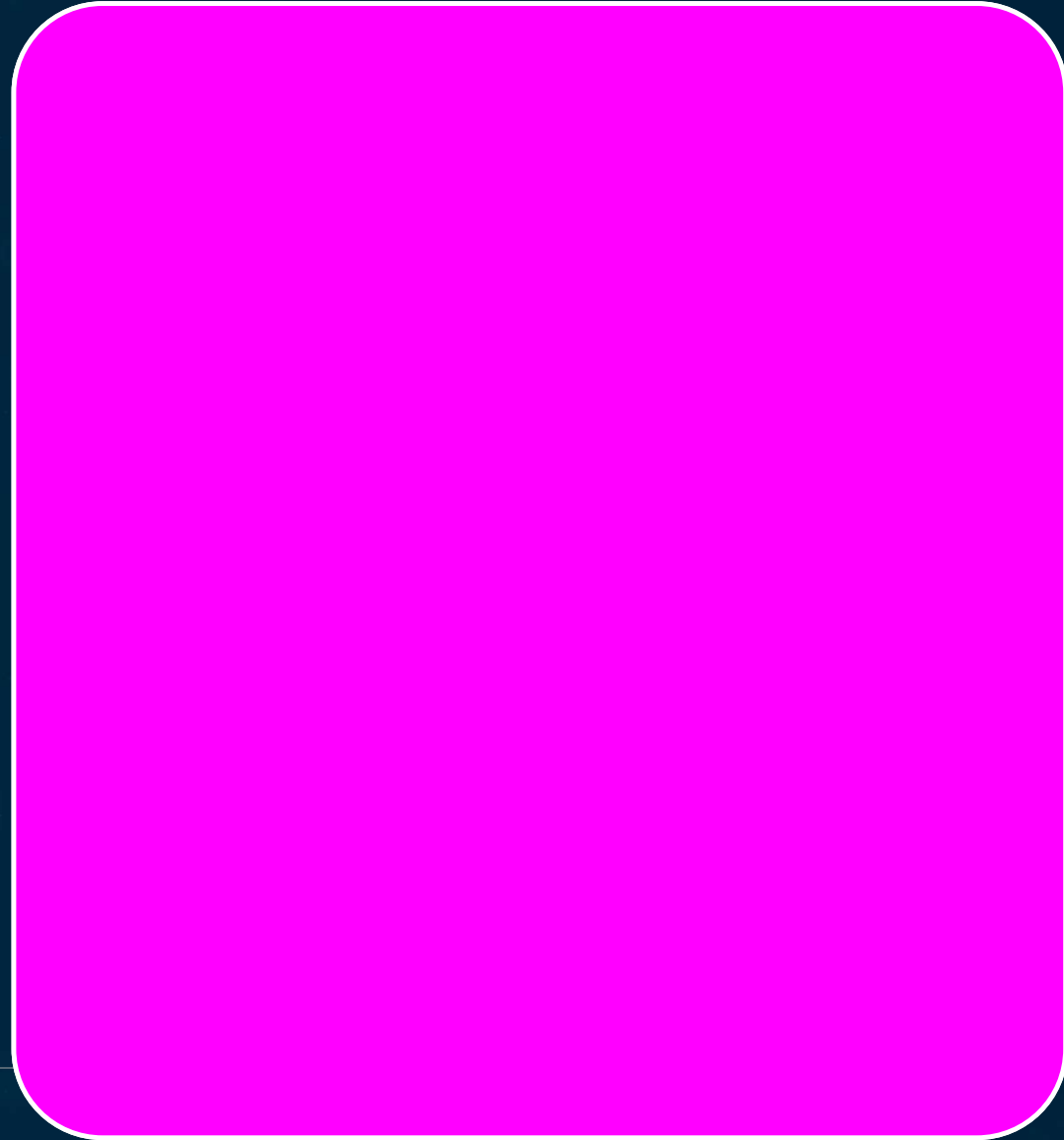


Recap

Four procedure types

Authority mapping

Policy > Procedure > Work Instruction



AI Asset Inventory & Documentation

Chapter 02 · Episode 4 — Dr. Michael Solomon



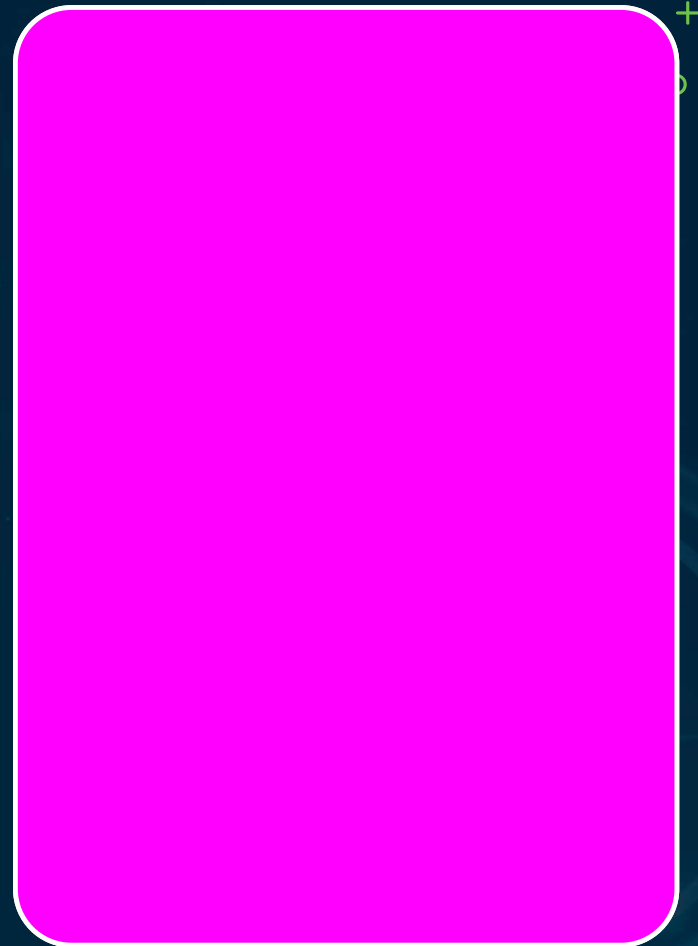
Minimum Inventory Fields

ID · name · owner · purpose

Data classification · EU AI Act status

Vendor · risk-register · DPIA refs

Unregistered = program gap



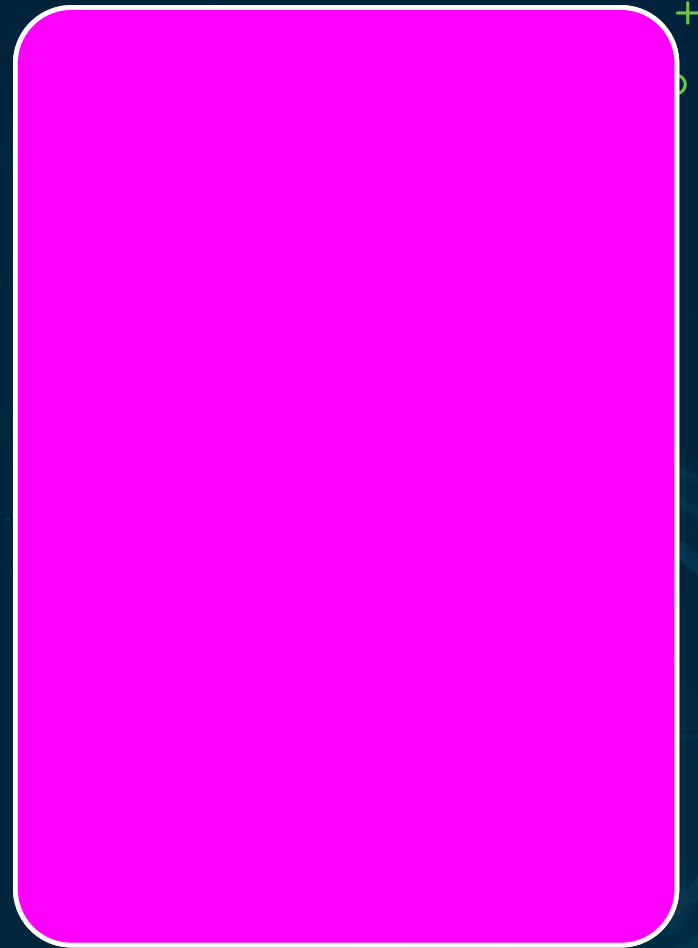
EU AI Act Status Field

High-risk under Annex III?

Conformity assessment + V&V status

GPAI → provider docs + data summary

Update when classification changes

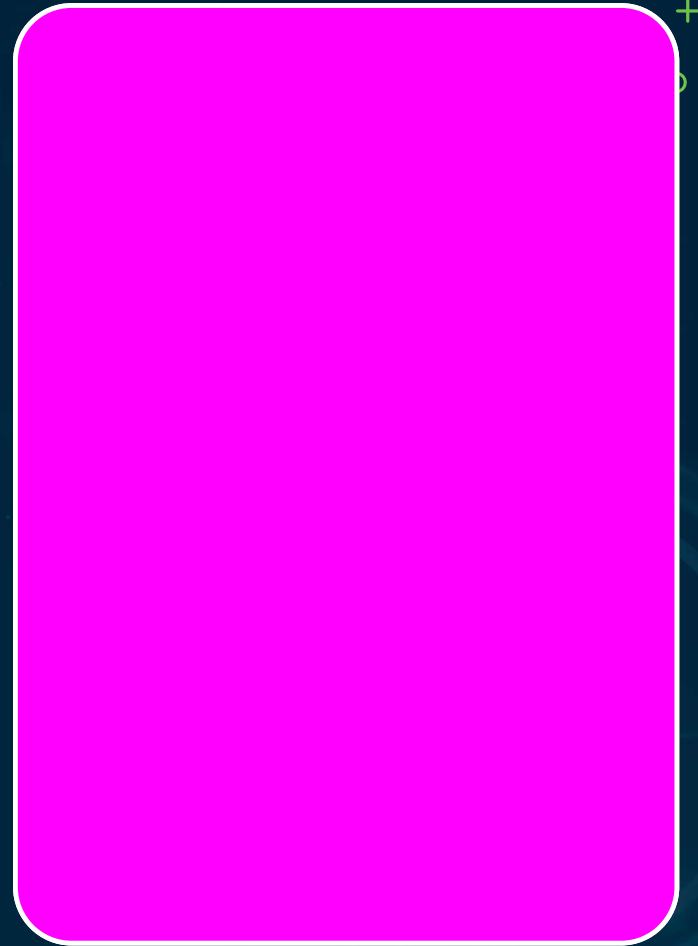


Model Card Reference

Every system carries a current model card

Updated on deploy · change · test cycle

Completeness = high-risk deployment gate

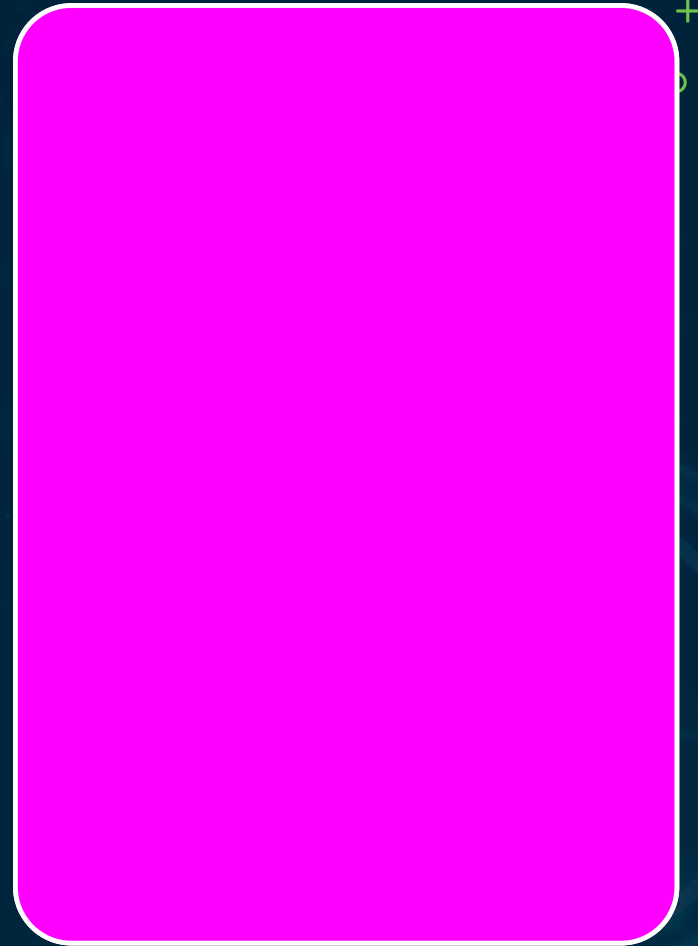


Data Classification Link

Records the data classes per system

Drives GDPR · DPIA · retention · access

A change triggers a risk-register review



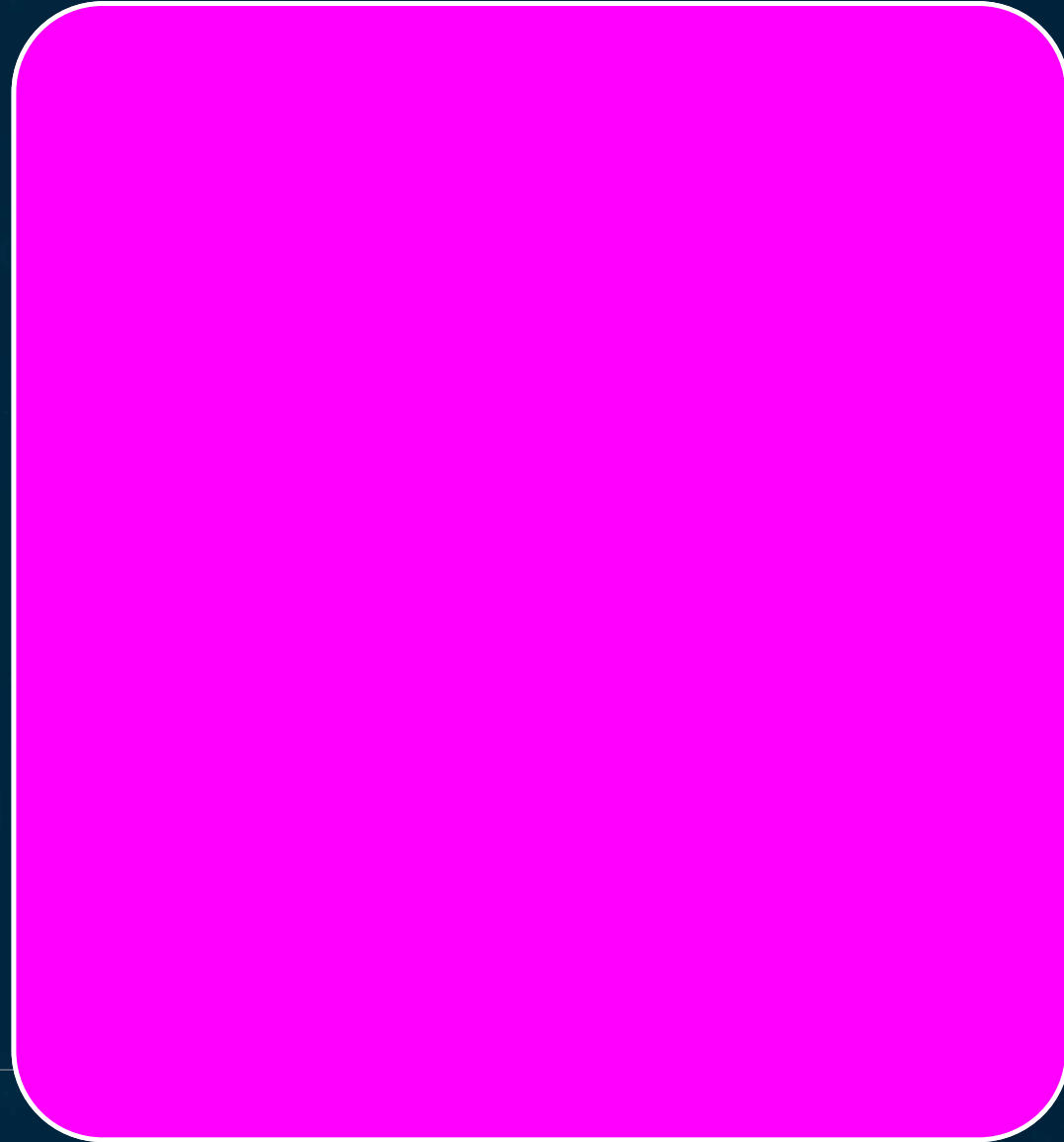
Vendor & Supply-Chain Fields

Name · tier · DD date · monitoring

Sub-supplier fields for tier 1 & 2

Mapping completeness = a
dashboard KPI

Concentration risk shows only
when mapped

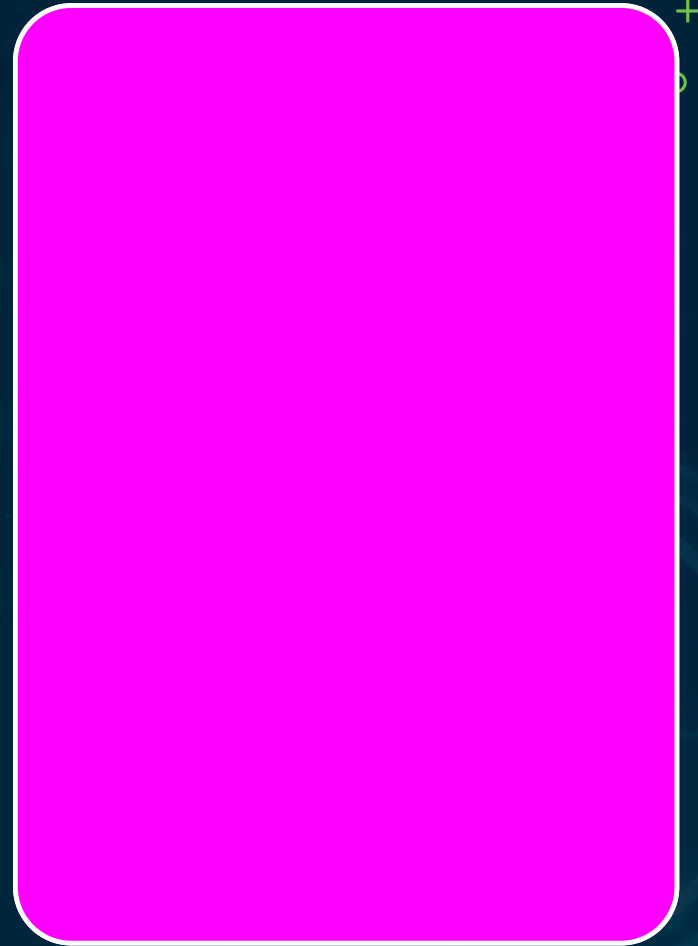


Regulatory Evidence

Produced to the DPA on request

Annual review required

Trigger on material program changes

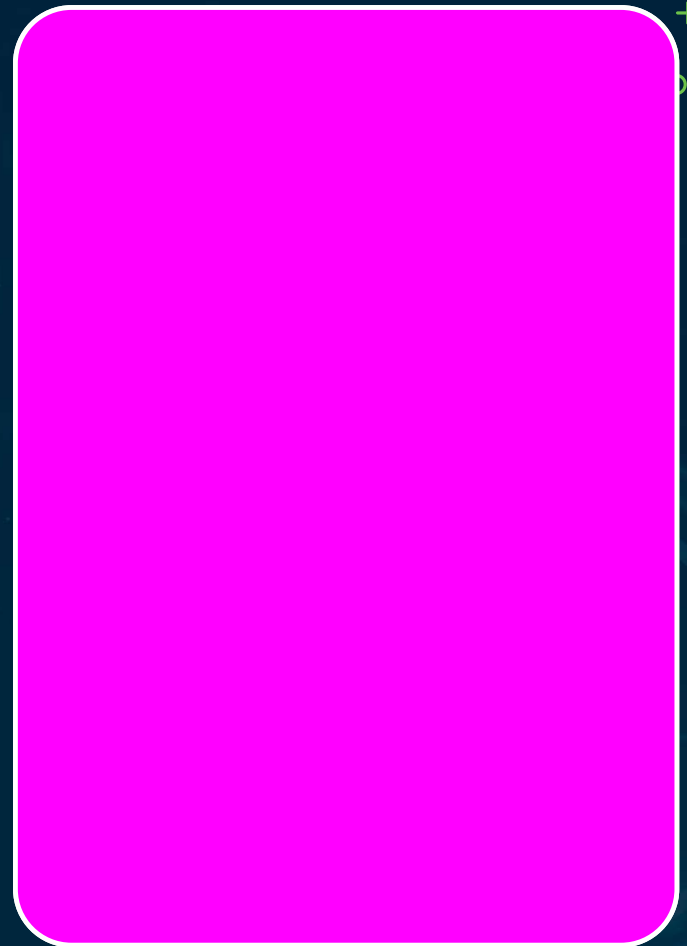


Inventory Gaps

Unregistered systems = accepted risks

Logged in the risk register

Exam: know the minimum fields



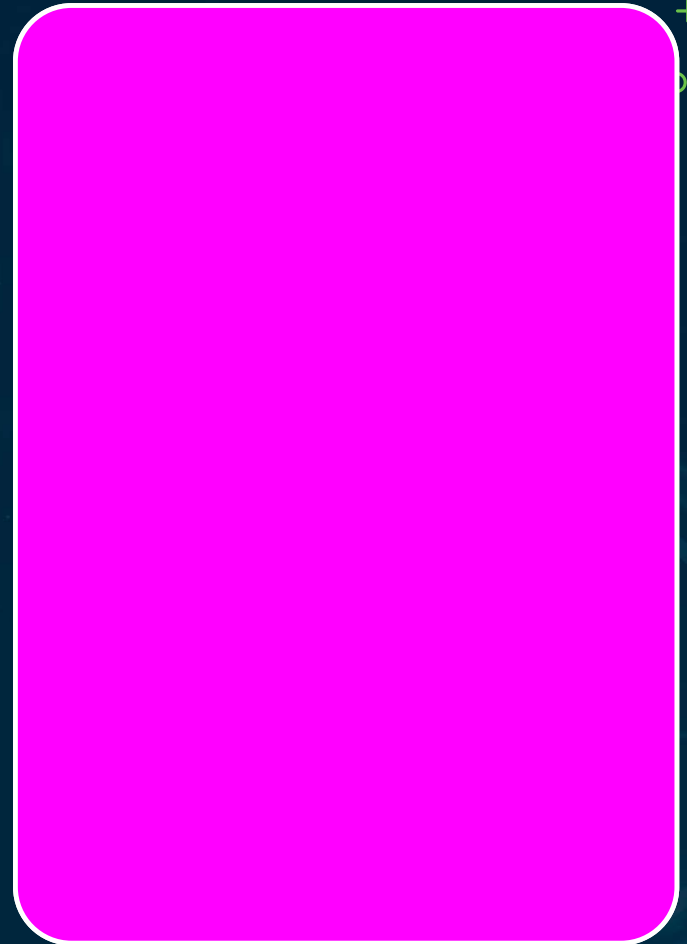
Recap

Min fields · EU status · model card

Data classification · vendor fields

System of record — unregistered = gap

Model card required for high-risk



Model Cards

Chapter 02 · Episode 5 — Dr. Michael Solomon

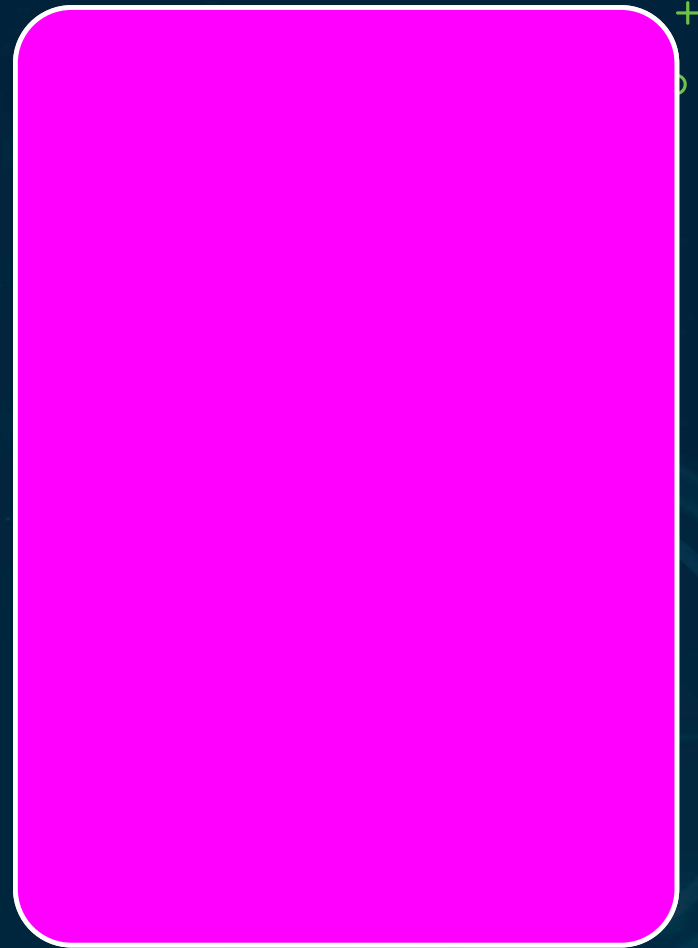


What a Model Card Is

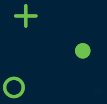
Structured doc that accompanies a model

Intended use & performance

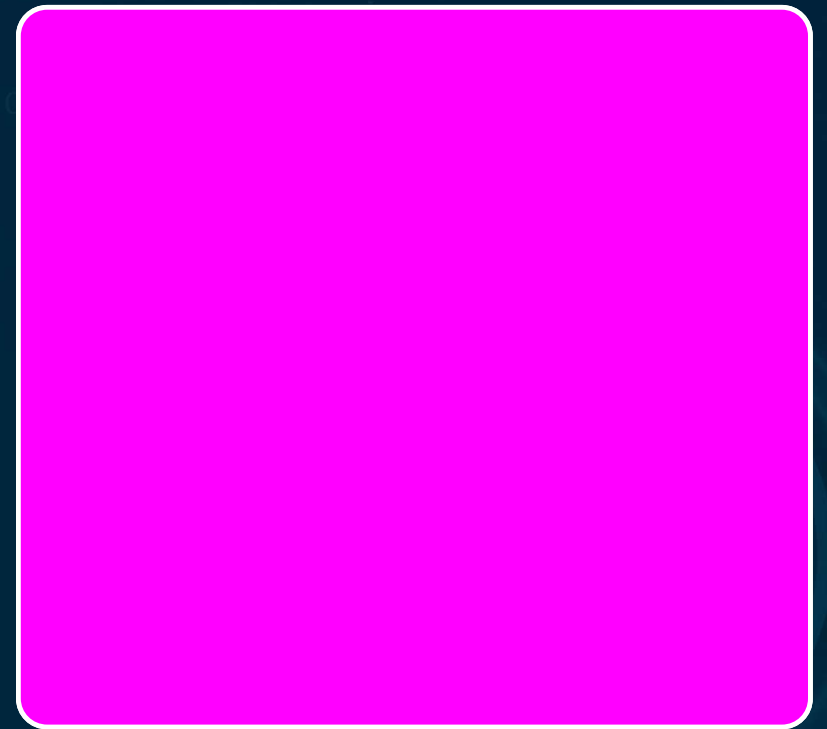
Limitations & ethical considerations



FROM RESEARCH TOOL → REQUIREMENT



EU AI Act
NIST AI RMF
ISO 42001



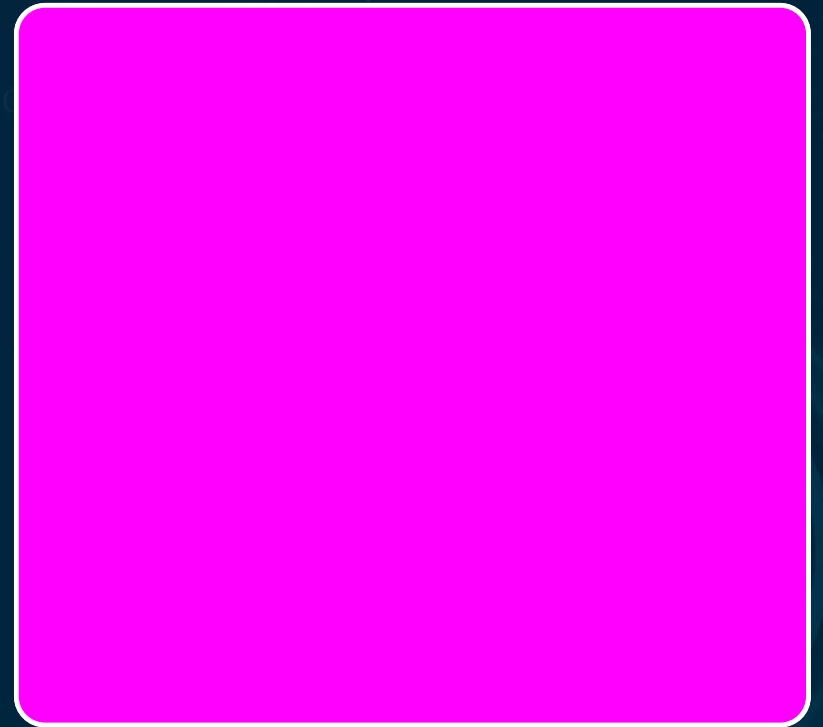
THE TECHNICAL PASSPORT



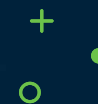
Required for all AI systems

Mandatory pre-deployment (high-risk)

Completeness = deployment gate



Core Sections 1–4



1
Model description



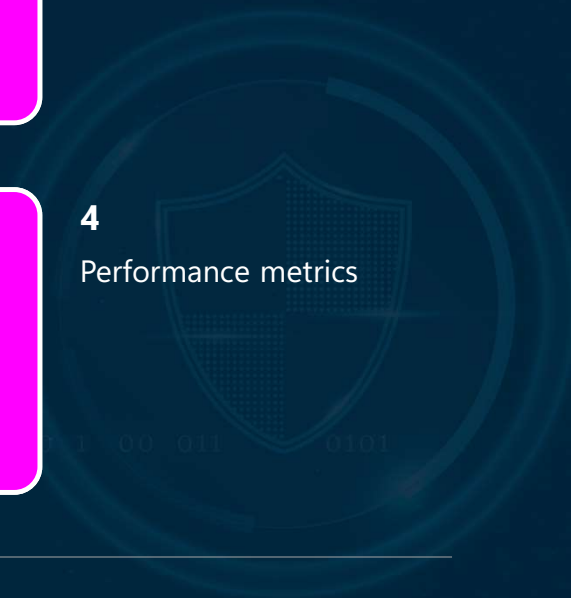
3
Training data summary



2
Intended use



4
Performance metrics



Sections 5–8



5

Limitations & failure modes



7

Security section



6

Fairness assessment



8

Audit logging /
explainability

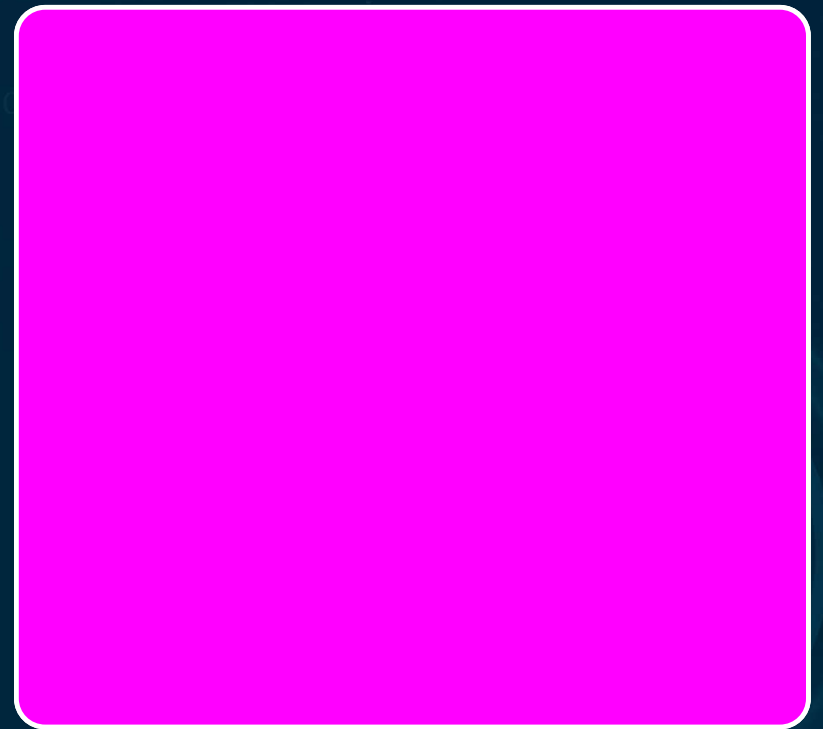


TRAINING DATA

Source, license, biases, provenance

Ties to the license register

Incomplete = deployment-gate failure



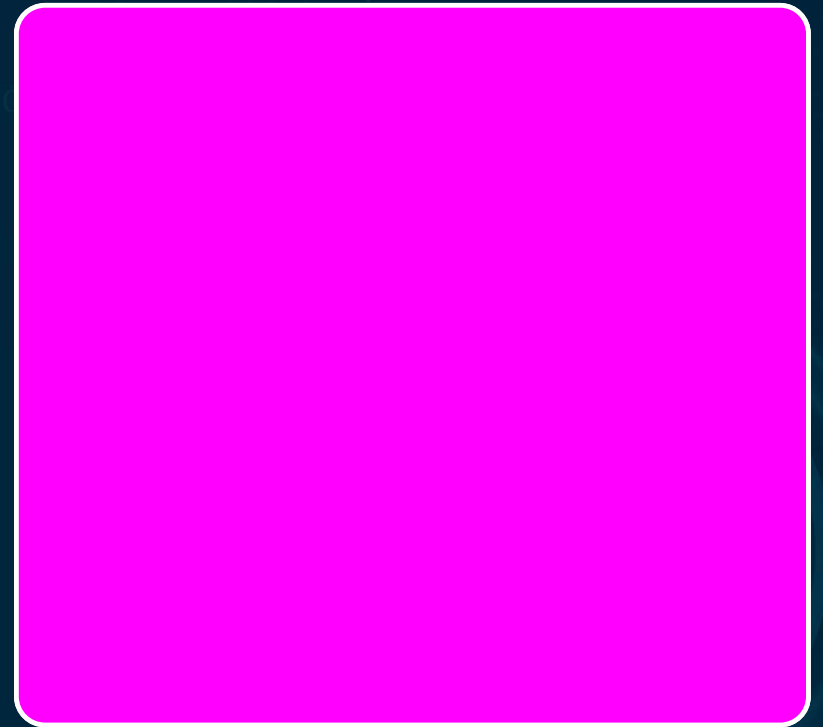
PERFORMANCE & FAIRNESS



Accuracy + fairness metric & score

Baseline date

Reference for ongoing monitoring

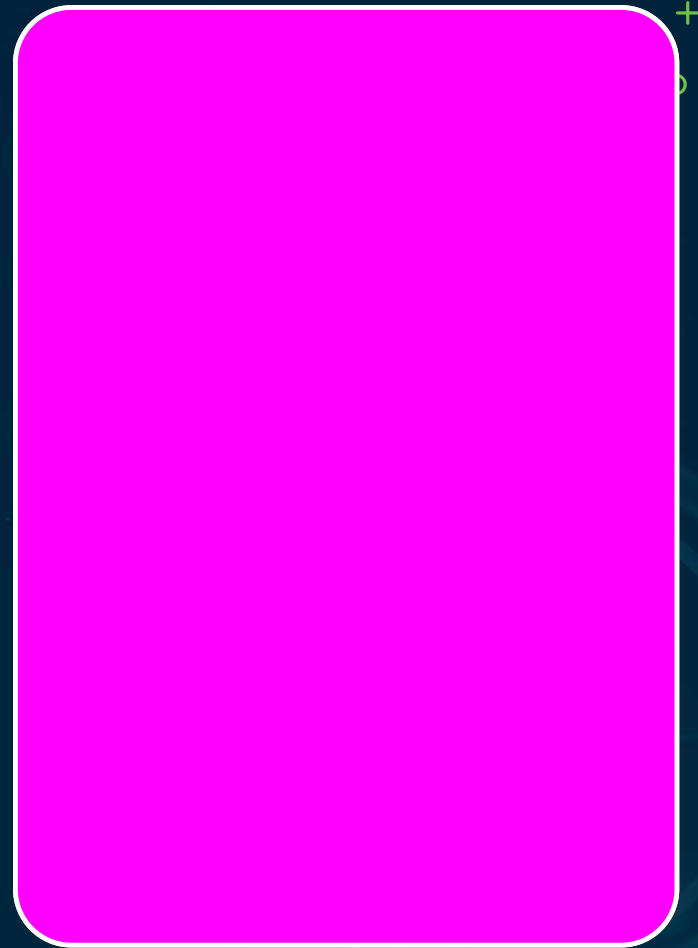


Model Card Lifecycle

Created → updated on change → archived

Version must match the model

Security lead signs off (high-risk)

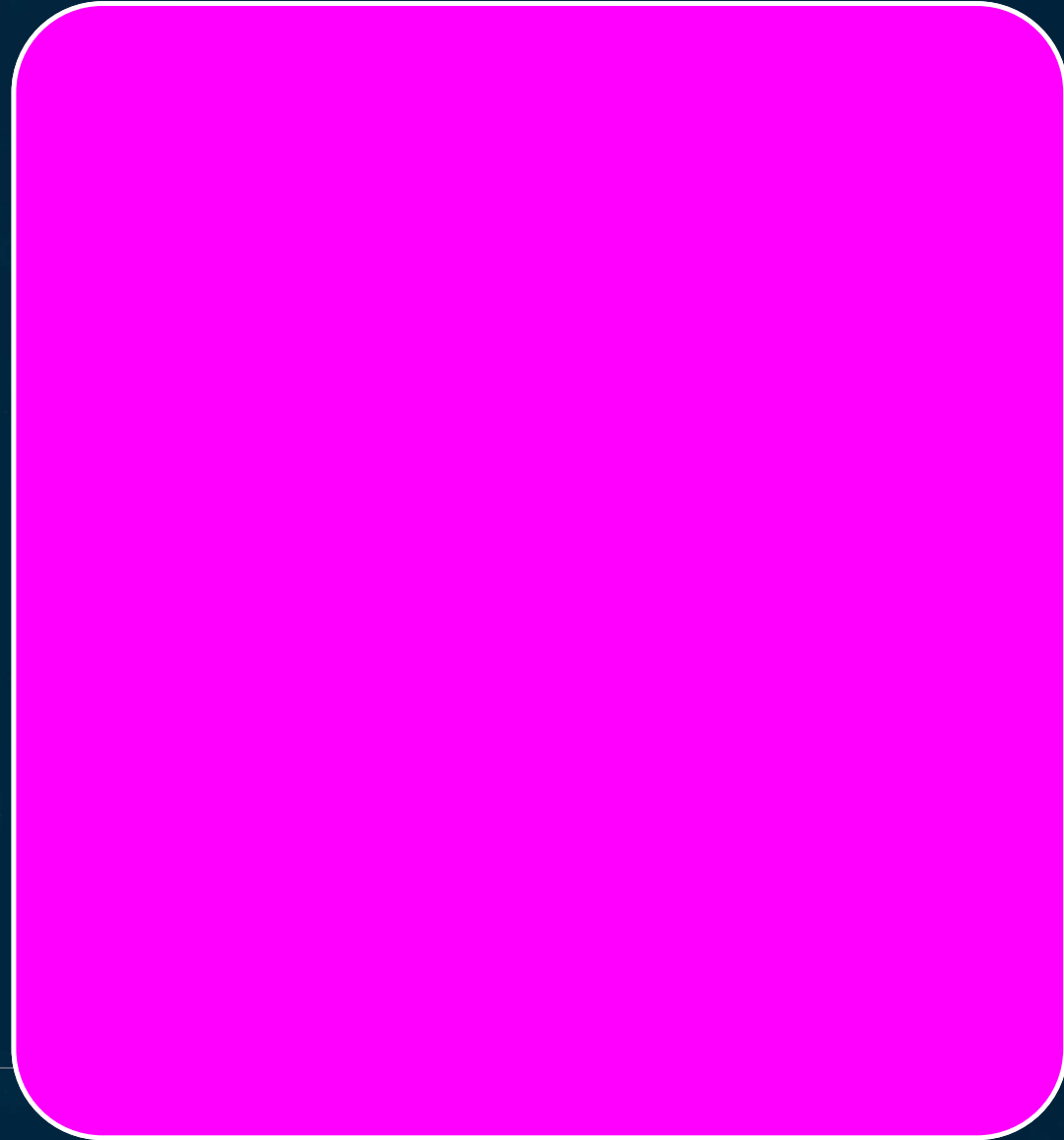


Recap

Card structure & required sections

Training-data connection

Completeness = deployment gate



Data Classification & Discovery

Chapter 02 · Episode 6 — Dr. Michael Solomon

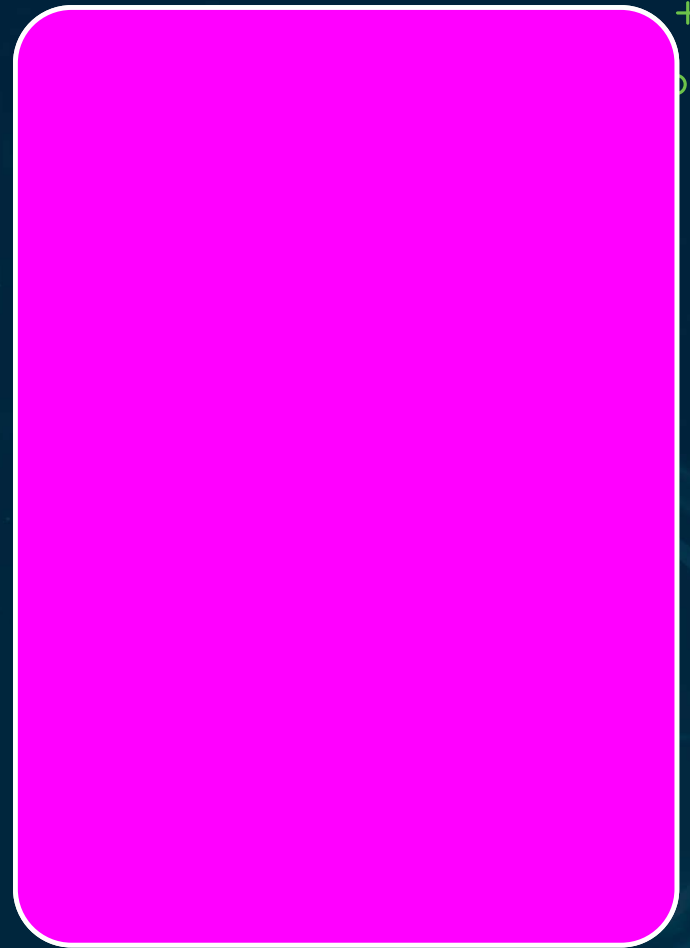


AI in Discovery Scope

Training stores, model artifacts, inference logs all need classification

New personal data → DPA review

Cross-reference the classification register to the AI asset inventory

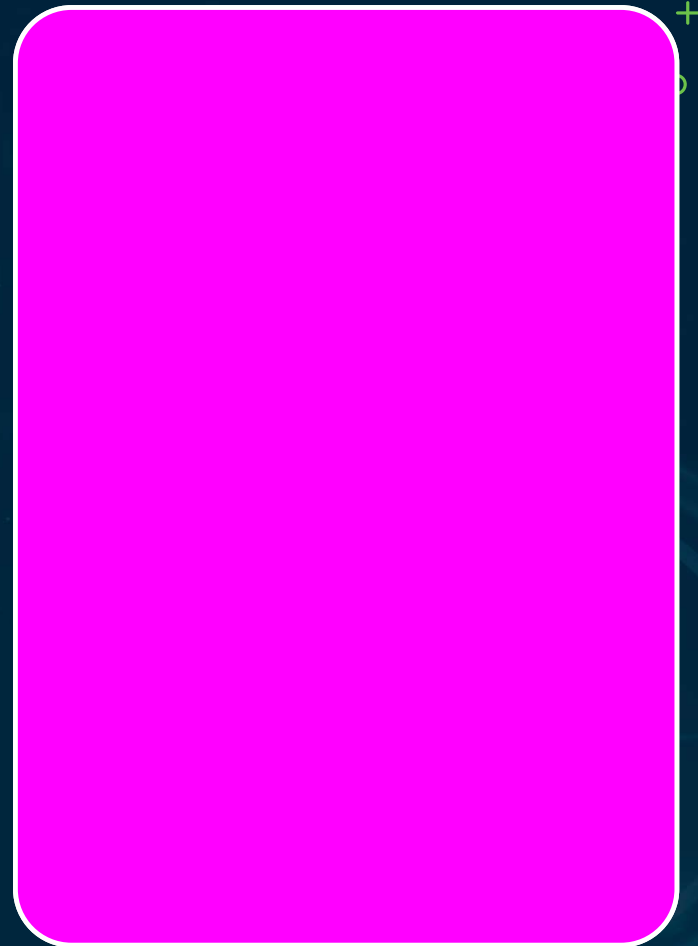


Data Safety Controls

Reduce sensitive-data presence before encryption applies

Masking, redaction, minimization operate at ingestion

The most secure data is the data never collected



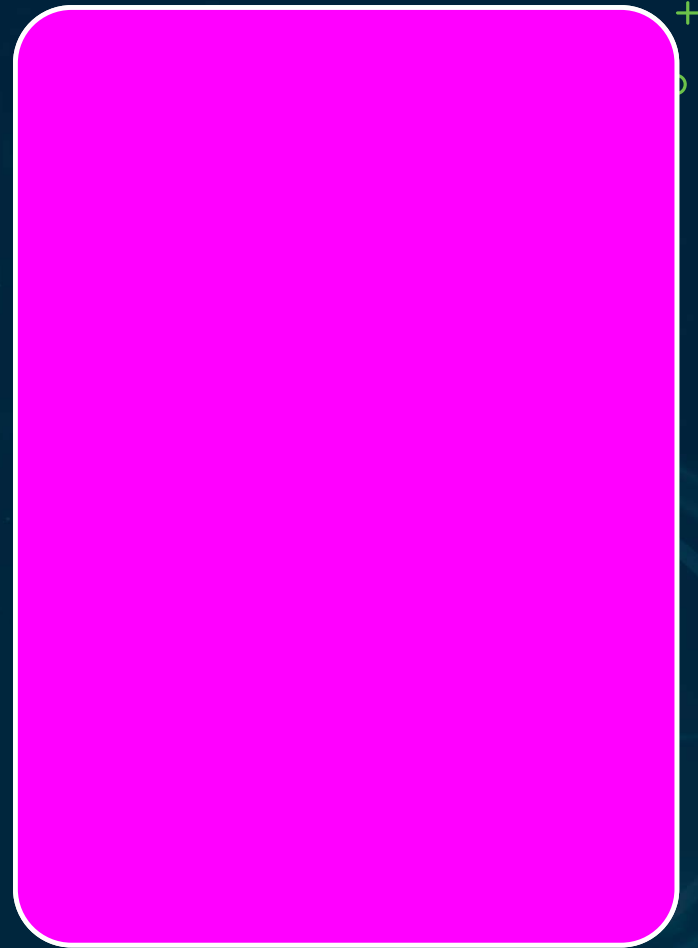
Data Classification

Tiers: public, internal, confidential, restricted

Label training sets; segment retrieval corpora

Classify at ingestion, not retroactively

Unlabeled regulated data = policy failure



Masking and Redaction Techniques



Static Masking

Permanent, irreversible transformation

Dynamic Masking

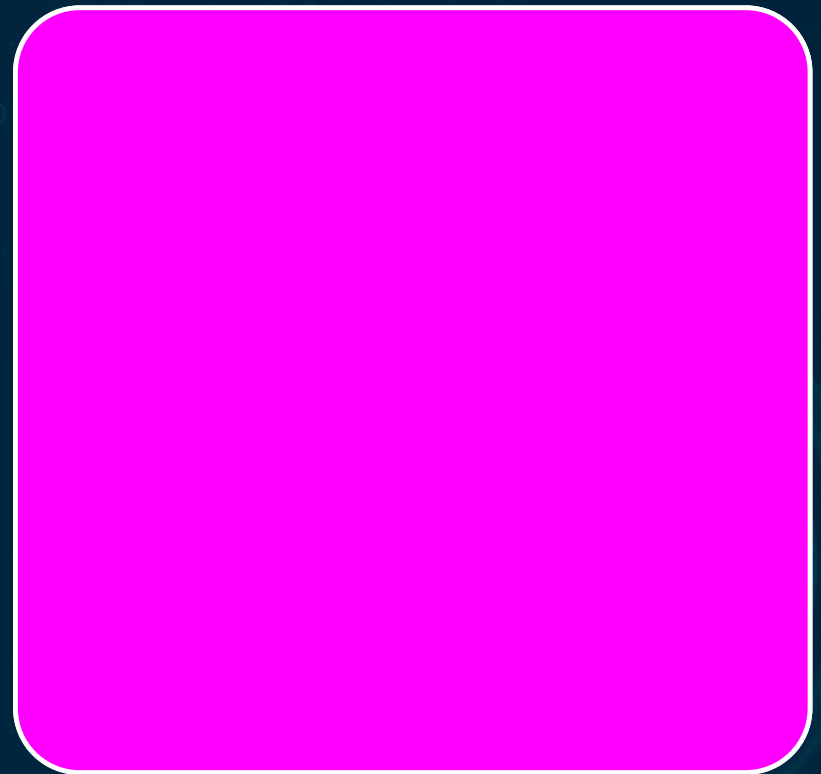
Runtime hide; storage unchanged

Tokenization

Reversible tokens + secure mapping

Redaction

Removes content entirely
— highest protection



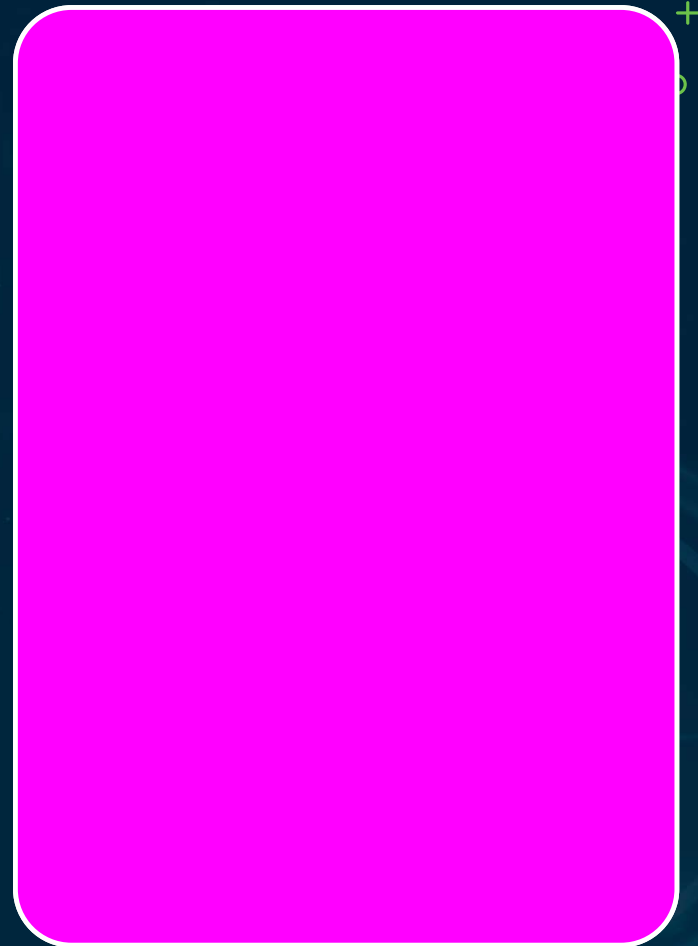
Data Minimization

Collect only what's necessary — metadata may suffice

Limit retention duration

Purpose-bound usage; no repurposing

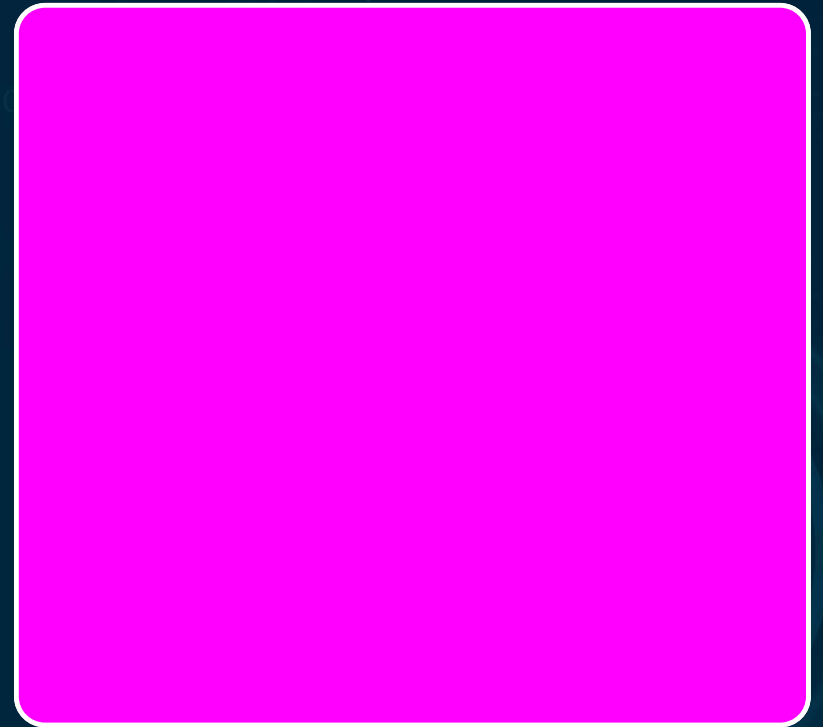
Accumulation is unbounded exposure



SHORTER RETENTION = SMALLER BREACH SURFACE

Continuous ingestion must be paired with disciplined pruning

Accumulation without governance is exposure without bound

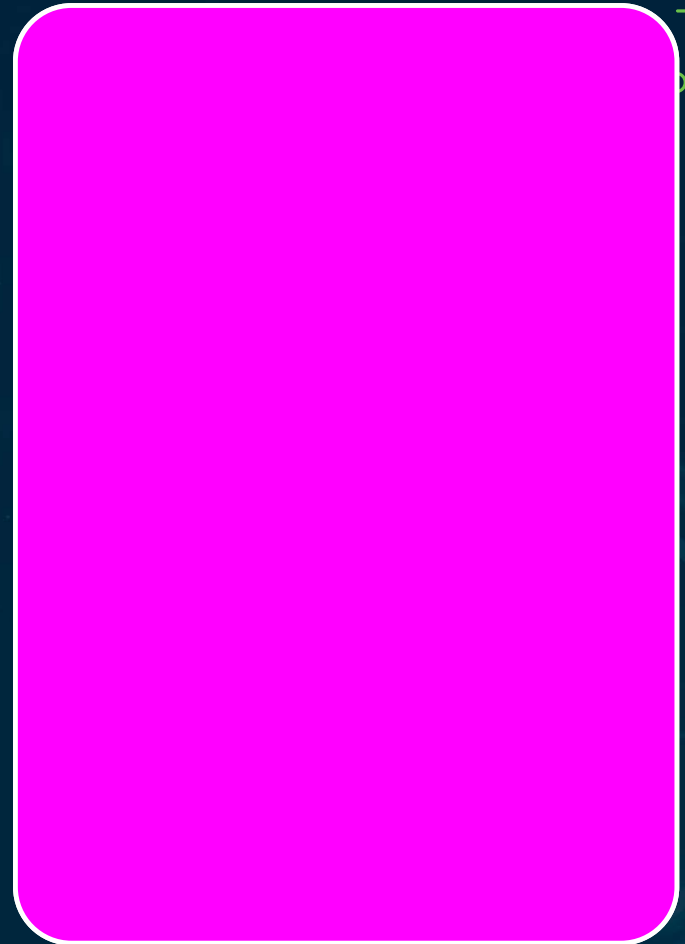


Program-Plan Integration

Classification determines GDPR obligations + DPA
+ retention

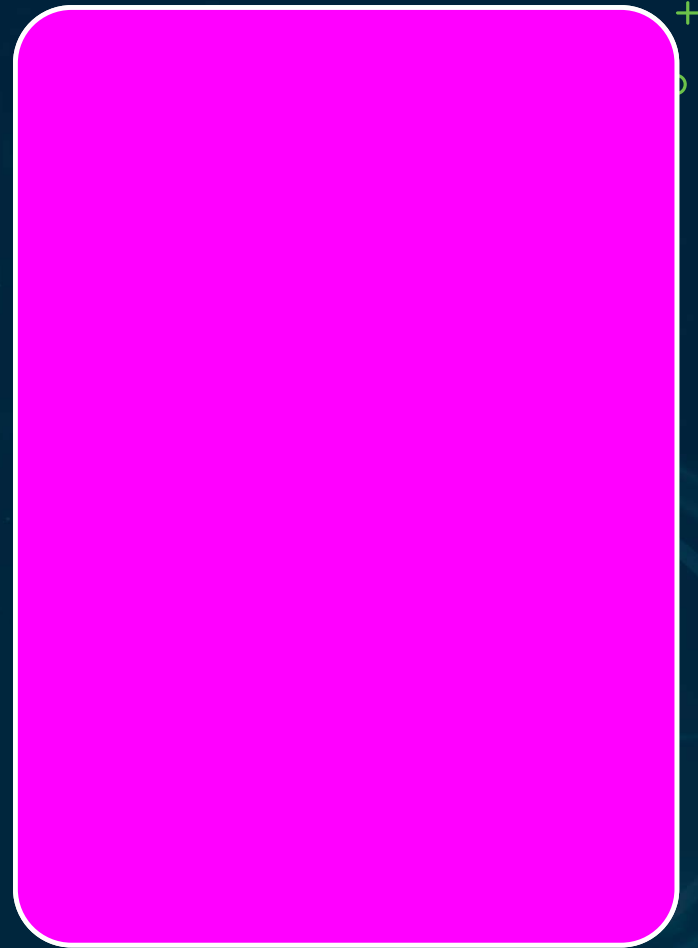
Align with AI-asset-inventory tiers

Restricted / special-category → tier-1 treatment



Recap · Classification & Discovery

- Classification scheme + discovery for AI systems
- Classification drives tier assignment
- Restricted / special-category = tier-1 AI treatment



Data Augmentation & Cleaning Controls

Chapter 02 · Episode 7 — Dr. Michael Solomon

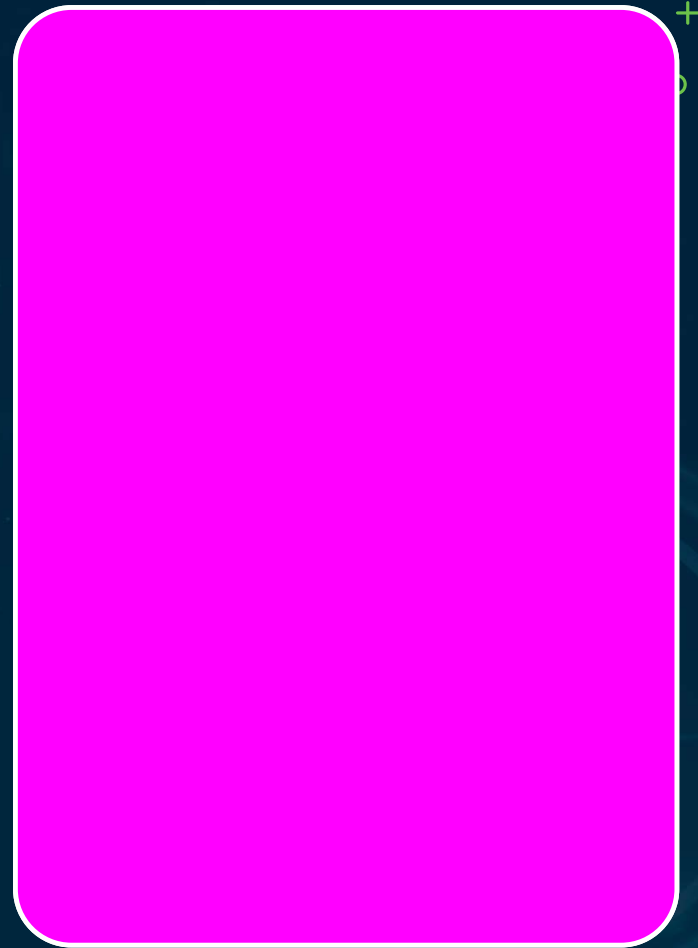


Why Data Is a Security Problem

Bad data creates bad models

Compromised data creates compromised models

Objectives: seven controls, quality → security



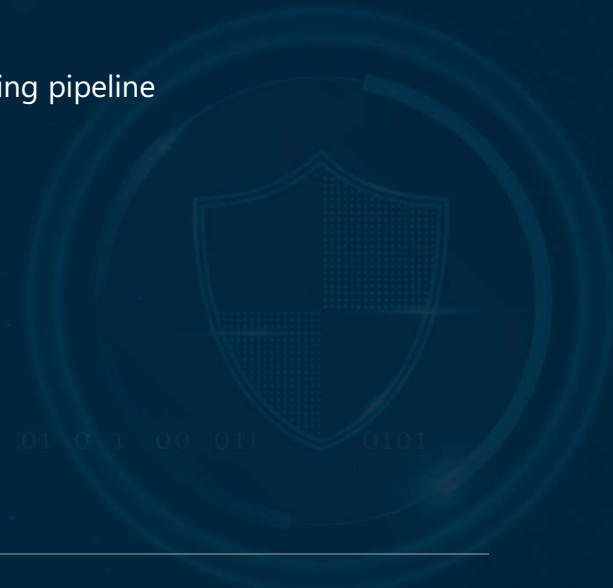
Traditional AppSec vs AI Data-Origin

Traditional AppSec:

- Vulnerability lives in the code
- Fix = patch the code
- Auditable — read the source
- Point-in-time fixes
- Attack surface = running app

AI Data-Origin:

- Encoded in model weights
- Fix = full retraining
- Opaque — can't read weights
- Found in production
- Attack surface = training pipeline

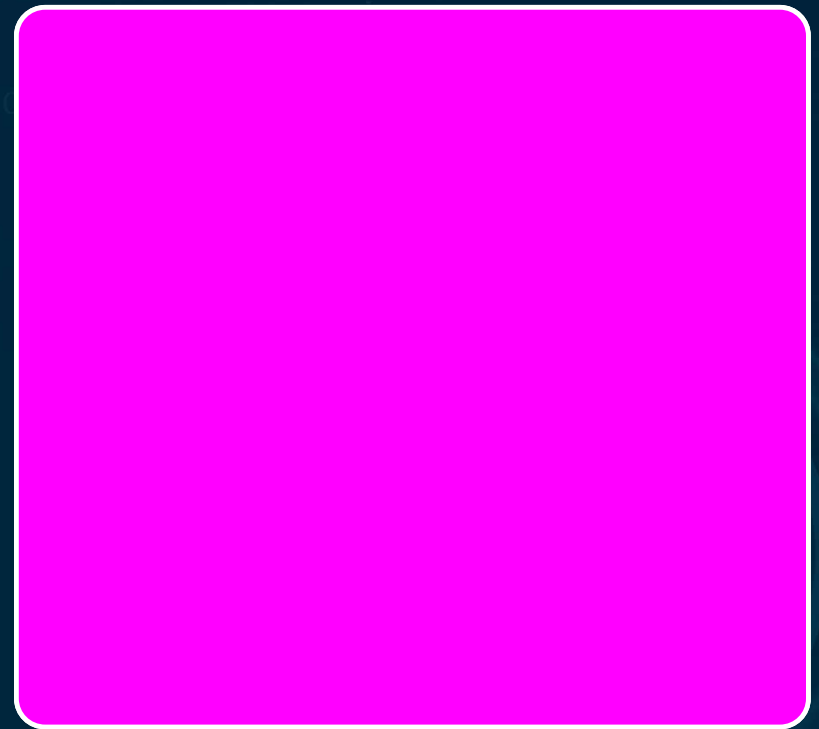


PREVENT BEFORE TRAINING



Prevention before training is the only cost-effective control

Data-processing controls ARE security controls



Seven Data Controls · 1–4



1 Cleansing

Remove invalid / duplicate
/ injected records



3 Lineage

Track journey
source → training



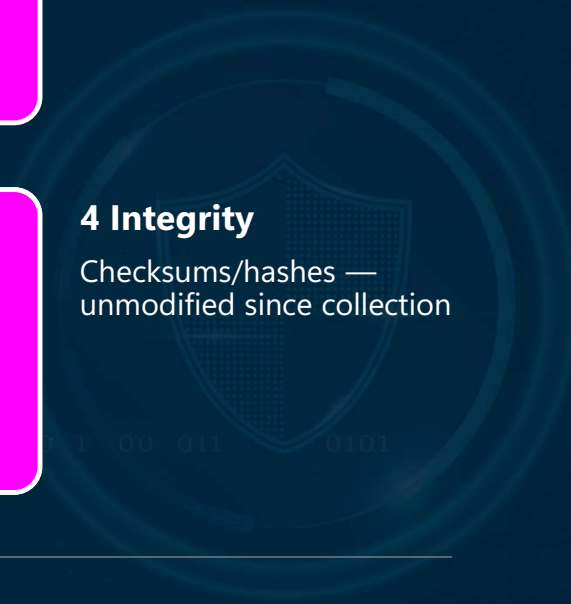
2 Verification

Confirm records are
authentic (semantic)



4 Integrity

Checksums/hashes —
unmodified since collection



Seven Data Controls · 5-7



5 Provenance

source legitimacy
+ authorization



6 Augmentation

review samples
for accuracy/bias



7 Balancing

proportional
class representation



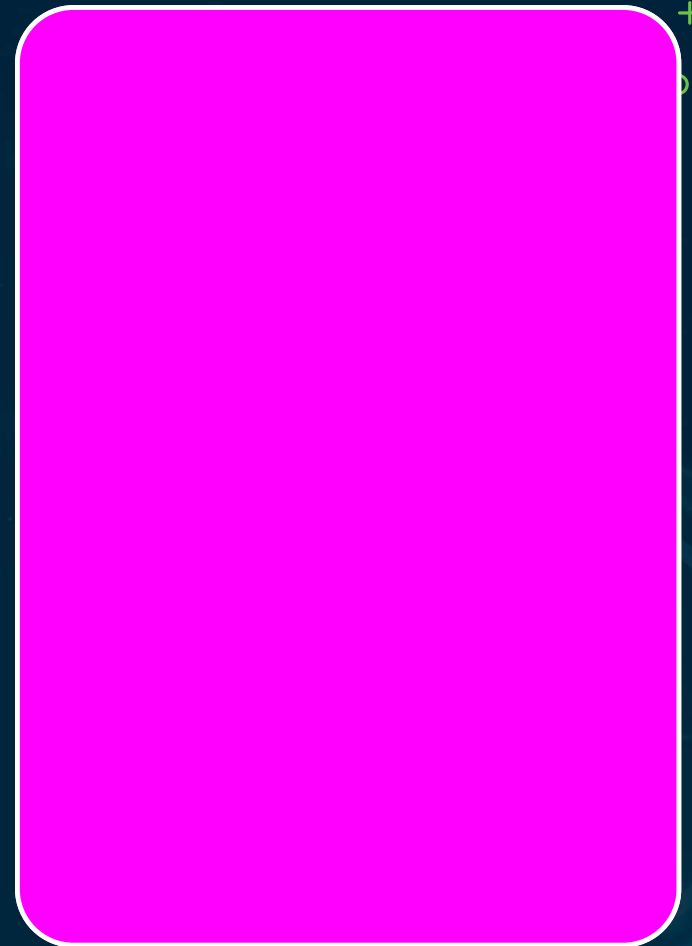
Controls 1–4 in Depth

Cleansing — structurally valid $\neq$ safe

Verification — catches semantic fakes

Lineage — evidence chain for in-transit modification

Provenance — trusted source + license (EU AI Act)



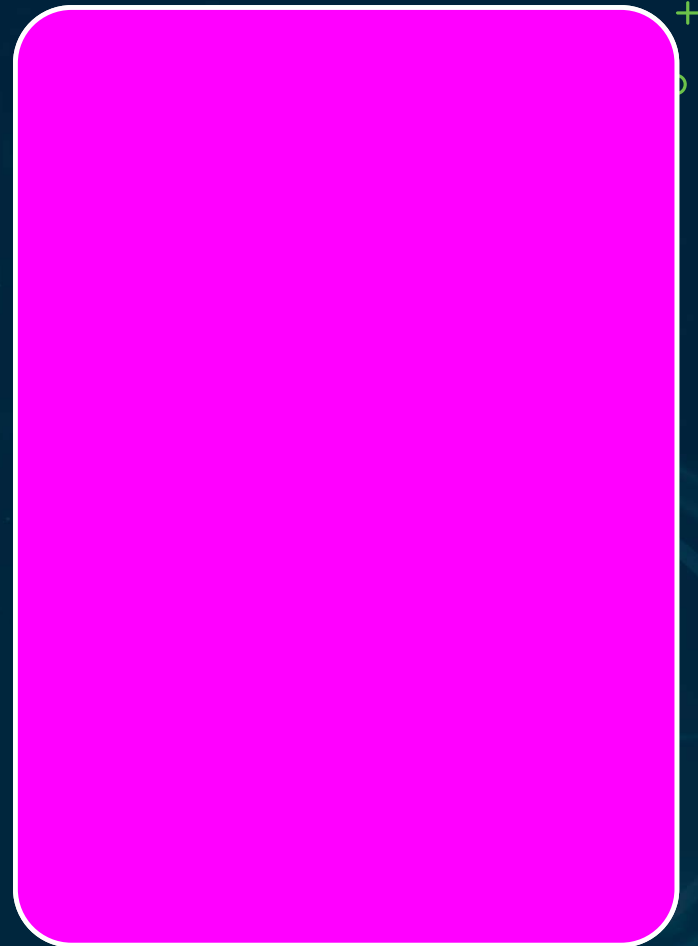
Integrity & Provenance

Hash or sign at collection; verify before training

Checksums simplest; signatures stronger

Provenance = security + compliance (EU AI Act, GDPR)

Provenance documents are part of the audit trail



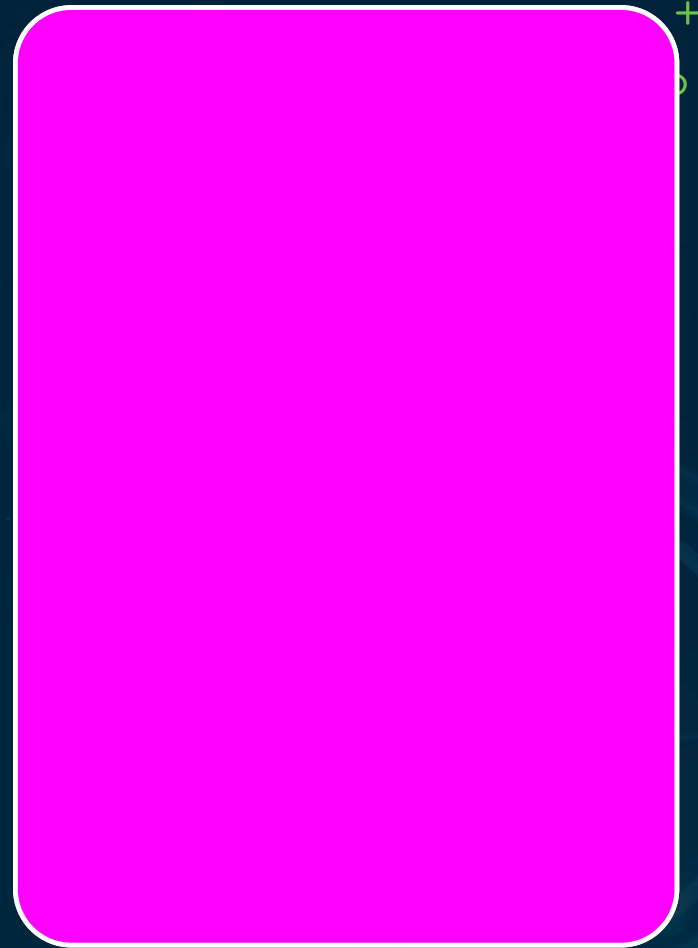
Augmentation & Balancing Risks

Augmentation can introduce systematic distortion

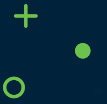
Review augmented samples stay unambiguous

10,000 : 100 balance = a false-negative factory

Imbalance creates predictable blind spots



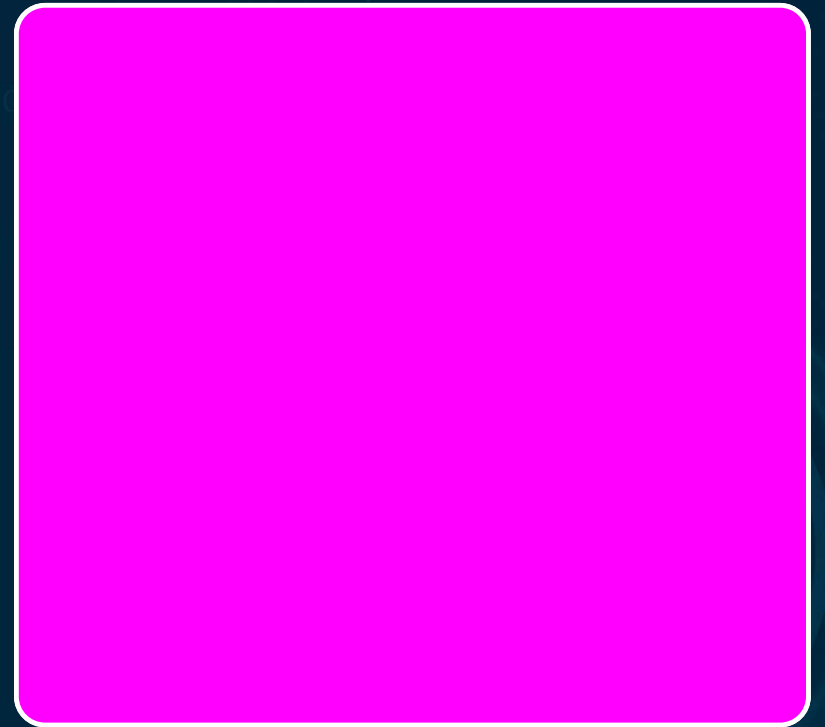
DOCUMENT EVERY TRANSFORMATION



Augmentation & cleaning steps go in the provenance record

Each transformation must be traceable

Undocumented steps block license-register completion

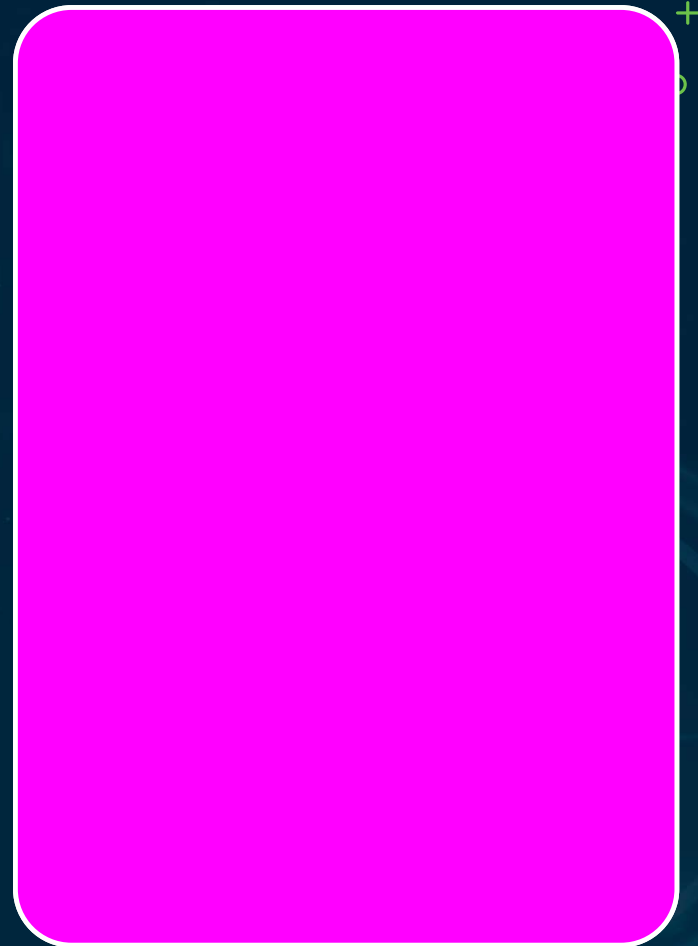


Recap · Augmentation & Cleaning

Augmentation & cleaning controls

Provenance documentation requirement

Program integration — quality failures → risk register



Secure Data Storage & Protection

Chapter 02 · Episode 8 — Dr. Michael Solomon

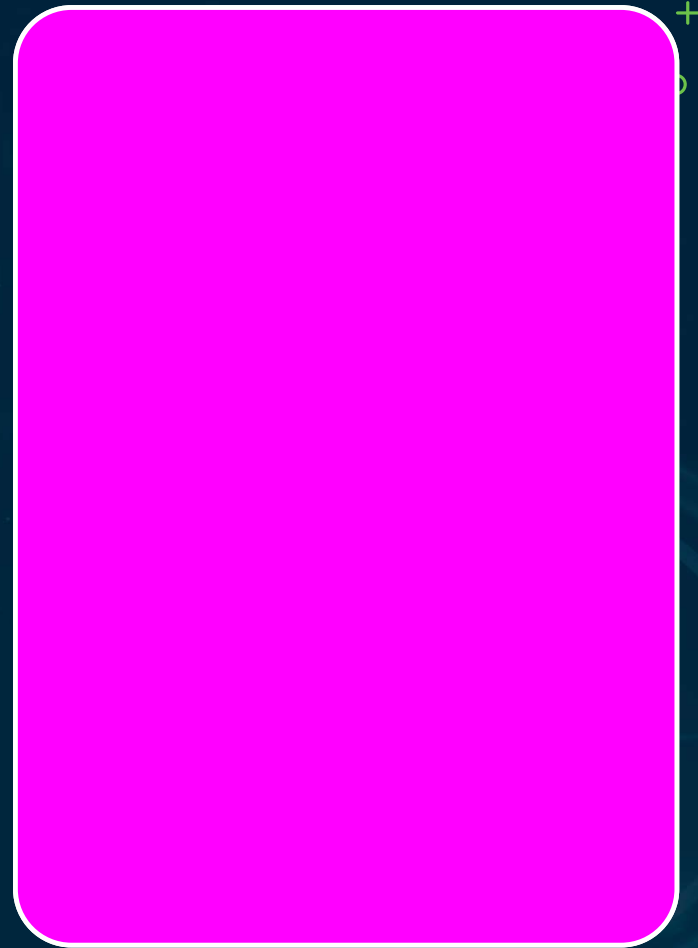


Data Is More Sensitive Than the Model

Training sets hold proprietary + regulated data

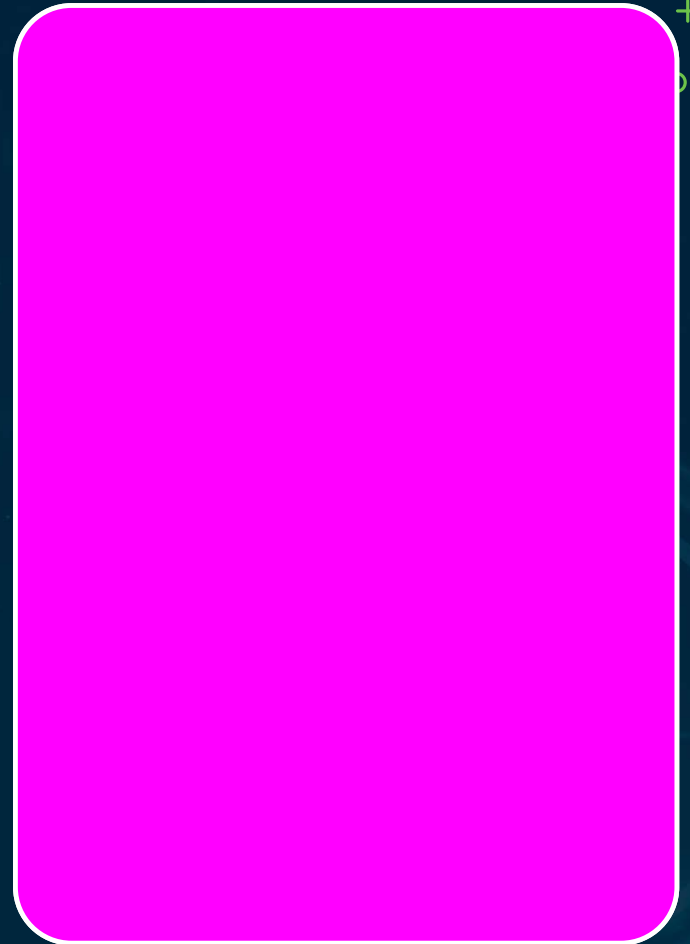
Inference-time exposure via prompts +
retrieved docs

Data is in motion throughout the system



Model Access ≠ Data Access

- RAG + vector DBs expand the exposure surface
- Query access must not grant raw-corpus access
- Independent control layers
- Sensitive leakage → check data access separately



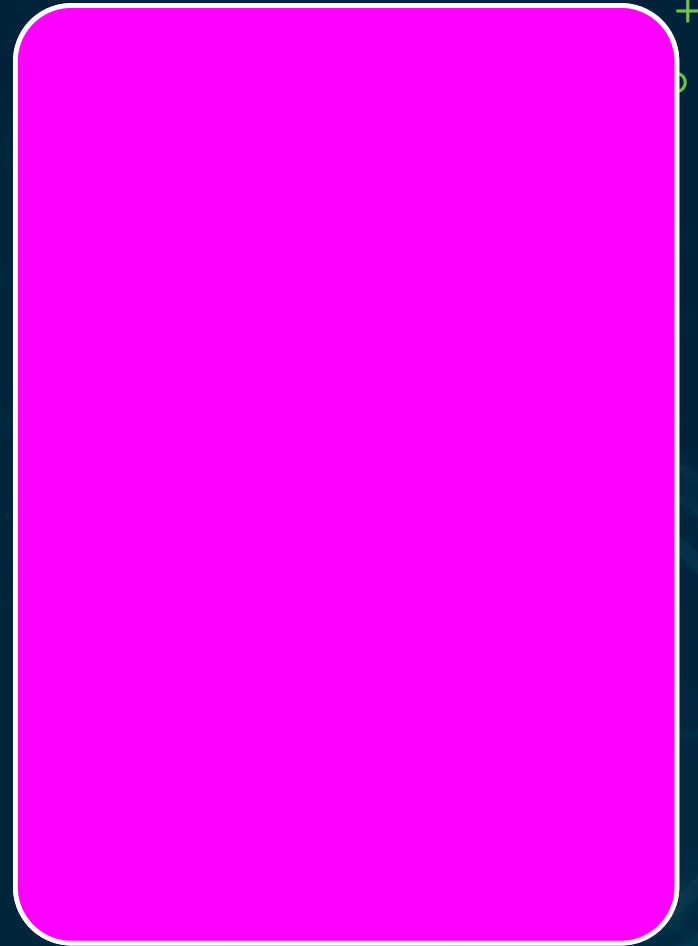
Dataset Segmentation

Classify by sensitivity, then segment by role

Fraud DB → finsec; EDR telemetry → SOC only

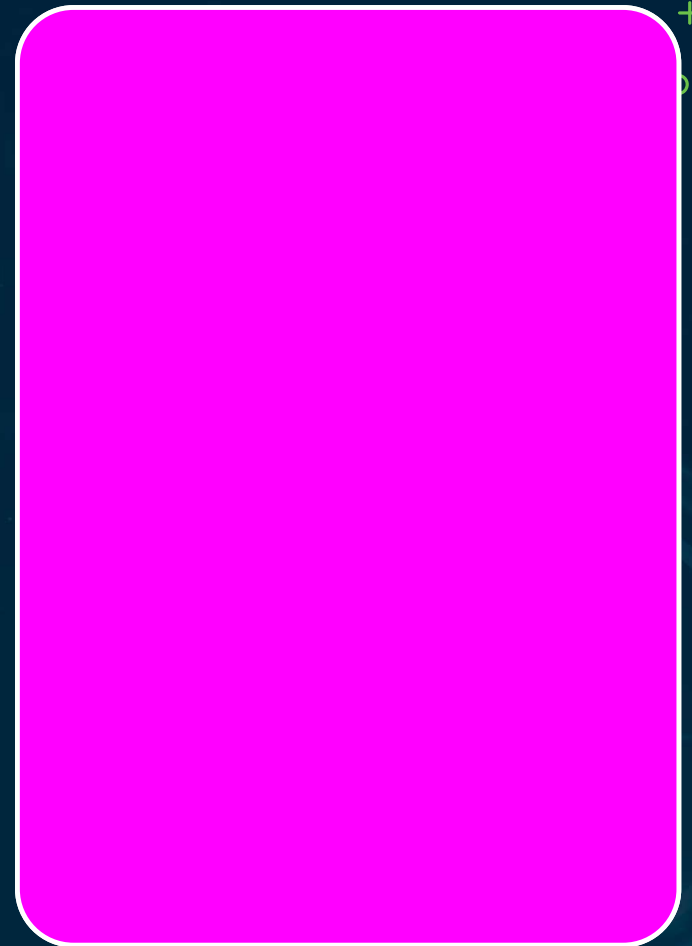
Regulated data gets extra isolation + audit

Cross-dataset exposure amplifies bias/privacy

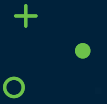


Access Controls: Read vs Write

- Differentiate read from write privileges
- Only a limited group holds write access
- Controlled ingestion with validation + approval
- Monitor read-only access for reconnaissance



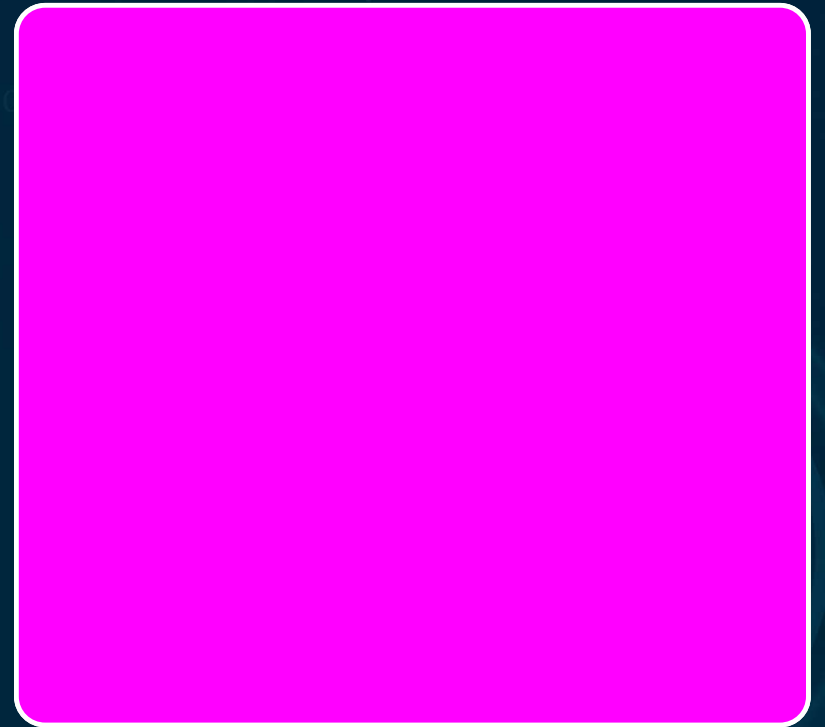
STRUCTURALLY ENFORCED, NOT USER TRUST



Data-layer controls are preventative defenses

Document per AI system in the asset inventory

Storage gaps = level-3 monitoring findings



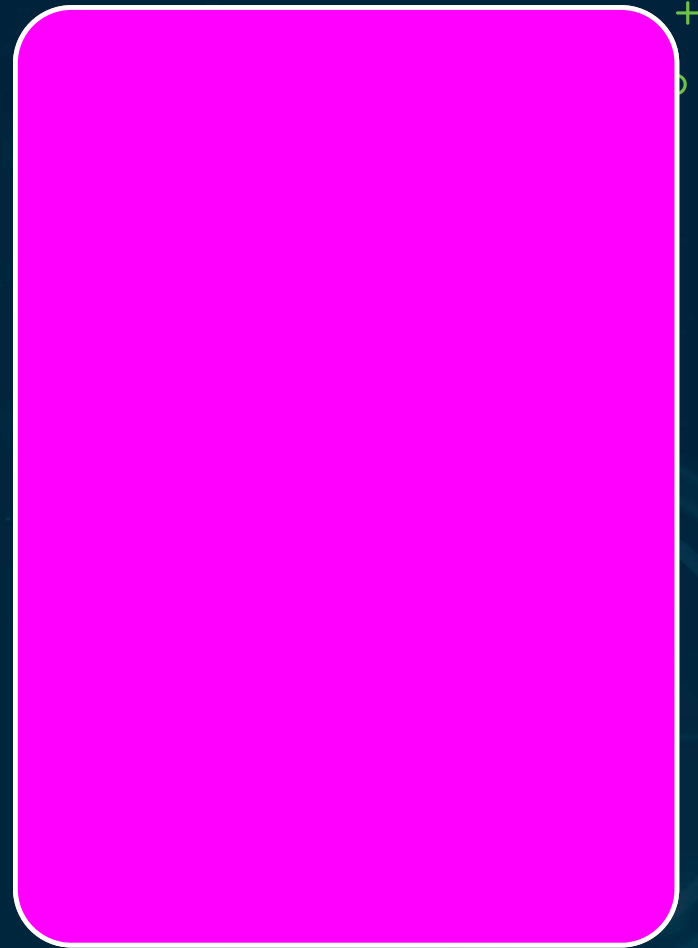
Deletion of Model-Embedded Data

Standard deletion misses model-embedded training data

Fine-tuning data persists in model weights

DPA must require written vendor confirmation

'Delete all data' clauses don't cover embedded data

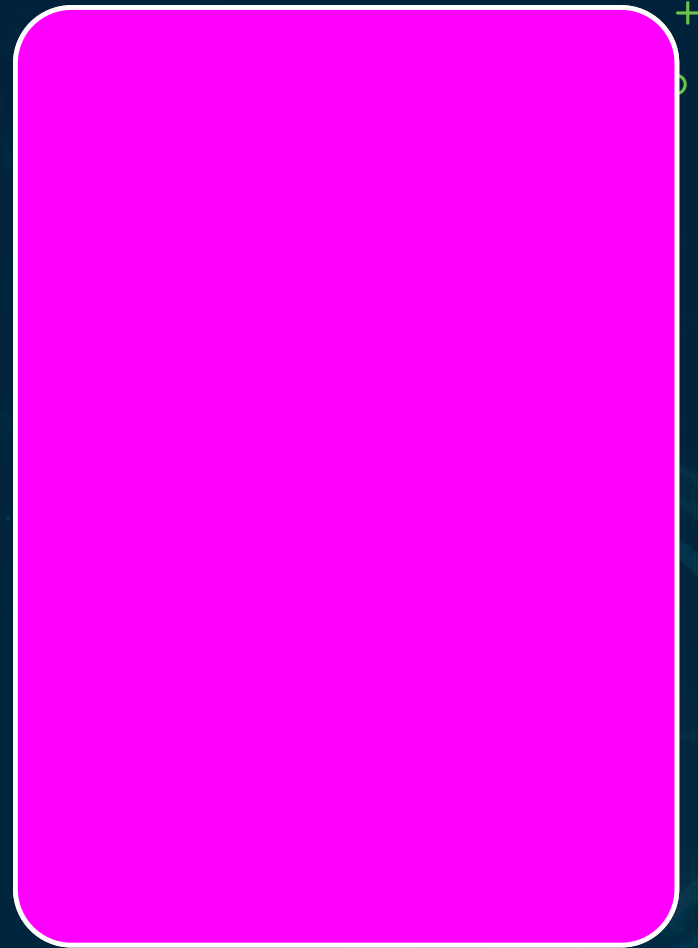


Encryption: Three States

Sensitive data exists at every lifecycle stage

At rest, in transit, in use

The exam tests all three independently



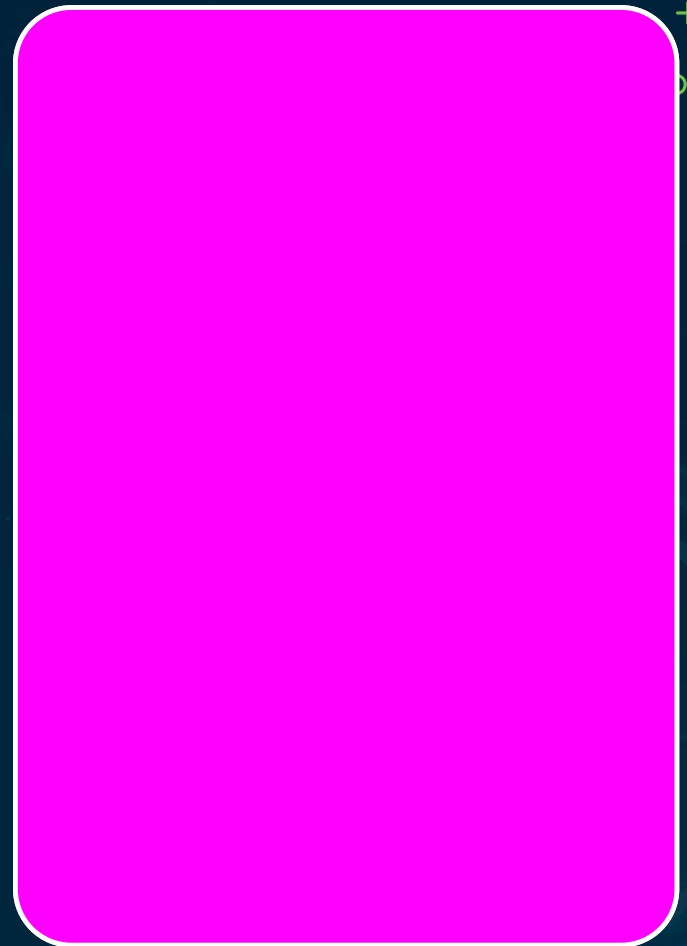
Encryption at Rest

Encrypt training data, corpora, vector DBs, weights

Storage-level + application-level layers

Key governance: isolate keys from data;
KMS rotation

Readable data on stolen media = at-rest failure



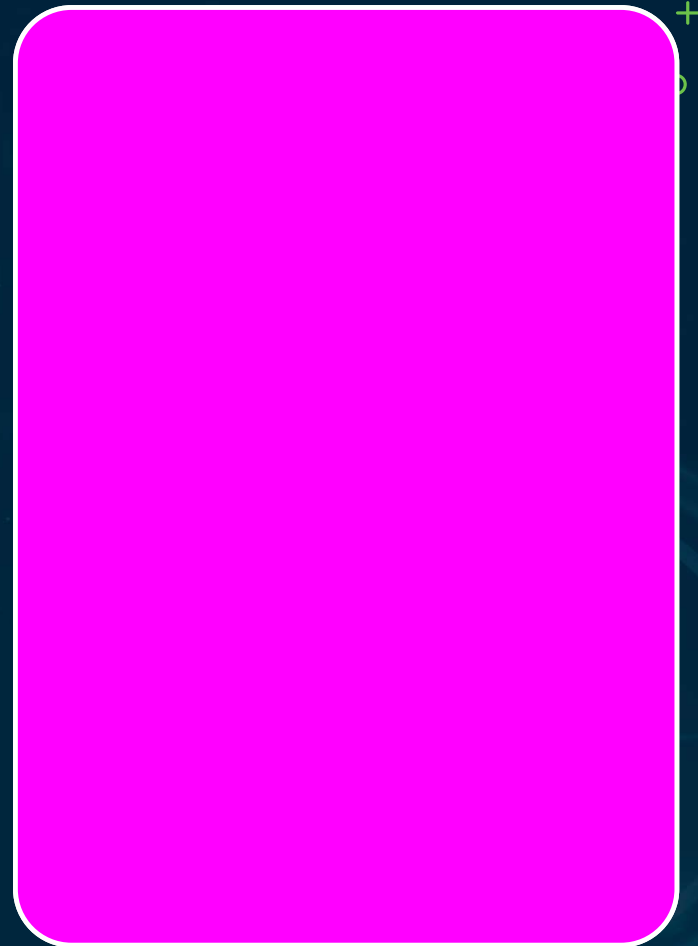
Encryption in Transit

TLS for all distributed AI communication

Mutual authentication for service-to-service

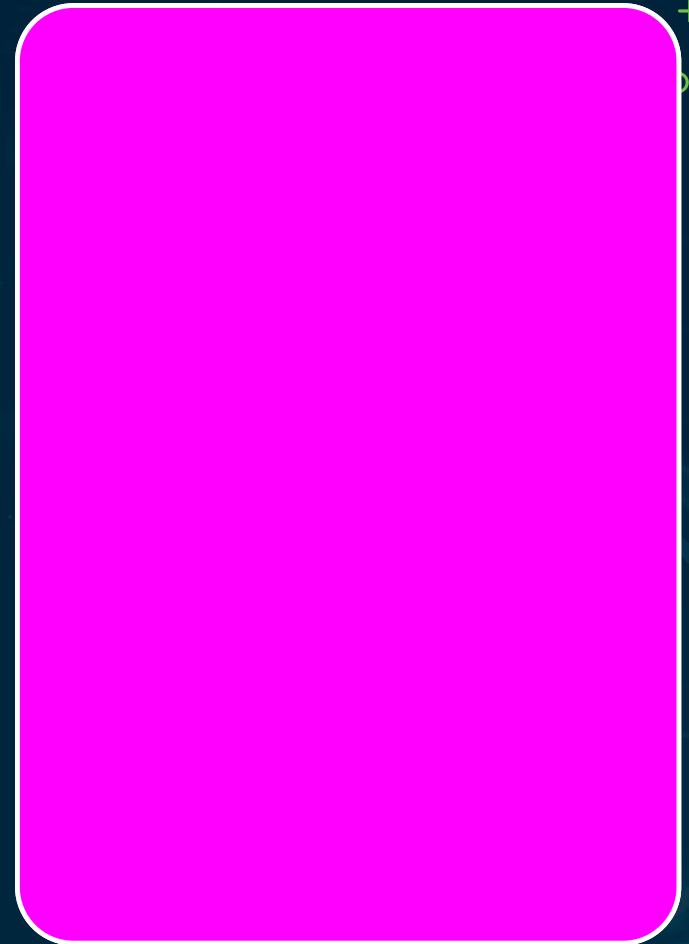
Certificate-lifecycle management; zero-trust

Intercepted traffic = in-transit failure



Key Governance & Lifecycle

Key rotation, revocation, crypto-operation logging
Regulatory alignment for protected data
Encryption without key governance is insufficient
One layer of defense-in-depth



Recap · Secure Data Storage

- Storage controls + MFA + least privilege
- Deletion obligations for model-embedded data
- Fine-tuning data persists in weights

